

SECUREFINANCE ERP · VERSIÓN ACADÉMICA 2.0

Documento técnico

Arquitectura, seguridad, operación, pruebas y trazabilidad

Stack: React, Express y Microsoft SQL Server

Generado: 24 de septiembre de 2026 a las 9:48 a. m.

Las pruebas conservan su estado documentado; este PDF no convierte revisión estática en evidencia de ejecución.

Documentación de SecureFinance ERP

Esta carpeta documenta la versión 2.0 de SecureFinance ERP y su implementación local con React, Express, Node.js y Microsoft SQL Server. Es una entrega académica/local: **no está declarada, certificada ni preparada para producción.**

La referencia funcional citada por el proyecto es `SecureFinance_ERP_Casos_de_Uso (1).pdf`, pero ese archivo no forma parte del workspace actual. Los UC01–UC14, PA01–PA32 y QC01–QC08 resumidos en estos documentos son la línea base disponible para esta auditoría; antes de una aceptación formal debe compararse también el PDF original.

Fuentes y criterio de verdad

Pregunta	Fuente autoritativa en esta entrega
¿Qué comportamiento se exige?	Especificación funcional y resultados esperados PA/QC. El código no puede rebajar una expectativa.
¿Qué está implementado ahora?	Archivos versionados de <code>apps/</code> , <code>database/</code> y <code>scripts/</code> , contrastados con contratos y trazabilidad.
¿Qué ocurrió realmente al ejecutar?	Registro de corrida y archivos enlazados desde Matriz PA01–PA32, conforme a la Guía de evidencia.

Una relación en la trazabilidad o la presencia de un SP demuestra cobertura estática, no comportamiento observado. Si estas tres capas discrepan, se registra el hueco; no se convierte la intención en evidencia.

Estado de verificación

- PA01–PA32 permanecen **Pendiente** en el registro oficial.
- QC01–QC08 permanecen **Pendiente** y son objetivos; no contienen resultados ni métricas inferidas.
- No existe un manifiesto de evidencia de runtime bajo `docs/evidence/`. Las salidas de lint, pruebas aisladas o compilación que se ejecuten fuera de ese flujo no cambian por sí solas una PA/QC.
- La documentación distingue diseño, procedimiento de prueba y resultado observado. Leer código no equivale a aprobar una prueba.
- `GET /api/health` y `pnpm sql:verify` son comprobaciones de conectividad, no una certificación funcional, de seguridad, continuidad u operación offline.

Inventario estático contrastado

La inspección del código fuente encontró 41 procedimientos, 6 funciones, 4 tipos de tabla y 11 triggers SQL. El rol `SecureFinanceApiExecutor` recibe 36 SP públicos; los otros 5 SP son internos. La API expone 36 operaciones HTTP concretas si las tres categorías de auditoría se cuentan por separado. Estos conteos sirven para detectar deriva documental; no prueban que una instalación haya sido ejecutada correctamente.

Cobertura automatizada y huecos conocidos

- Playwright cubre las tres páginas públicas en Claro/Oscuro y 320/768/1280. Una configuración separada recorre 14 vistas privadas contra API y SQL reales, con cuentas sintéticas de una base `_Test`, dos roles, dos temas, comprobación Axe y capturas en `docs/evidence/runtime/ui/`. Es cobertura parcial: no sustituye teclado/zoom completo, diálogos en edición ni toda PA13–PA25.
- `pnpm test:integration`, habilitado con `RUN_SQL_INTEGRATION=true`, comprueba con el login real de la API el SP autorizado y la denegación de lectura, escritura y procedimientos internos. No sustituye las carreras ni el aislamiento completo de PA29.
- No hay generador del dataset QC de 1,000 clientes, 10,000 productos, 50,000 facturas y 250,000 líneas, ni arnés de carga de cinco sesiones; PA30/QC01/QC02 no son ejecutables con el volumen prescrito tal como está empaquetado.
- `database/tests/04_sale-rollback-fault.sql` inyecta un fallo después del encabezado mediante un trigger temporal, exclusivamente con conexión administrativa y base `_Test`; la misma reversión elimina trigger y fixtures. Demuestra un punto concreto, no toda la matriz de fallos de PA06/QC03.
- Los scripts de respaldo/restauración y las pruebas SQL son herramientas de ejecución; sin acta, salida íntegra y evidencia enlazada no demuestran PA29, PA31 ni QC07.

Requisitos de instalación

- Windows con PowerShell 7 o Windows PowerShell 5.1.
- Node.js `>=24.18.0 <25` y `pnpm 10.34.4`, exactamente como declara `package.json`.
- Microsoft SQL Server 2022 (16.x) o posterior. El script selecciona compatibilidad 160 para 2022 y 170 para 2025 o posterior.
- `sqlcmd` disponible en `PATH`, con soporte de modo SQLCMD y de la opción `-C` usada por los scripts.
- Una cuenta Windows con autenticación integrada y autoridad para crear la base, el login SQL y el usuario de base.
- Autenticación SQL habilitada y TCP local configurado para que la API use el login de mínimo privilegio. Los valores predeterminados esperan administración en `.\SQLEXPRESS` y aplicación en `127.0.0.1:1433`; adapte instancia/puerto a la configuración real.
- La instancia debe exponer `Central America Standard Time` en `sys.time_zone_info`, condición que el instalador comprueba antes de crear la configuración de Guatemala.
- Un navegador actual para uso interactivo. La suite E2E incluida usa el canal local `msedge`; no se declara una matriz de navegadores aprobada hasta ejecutar PA24.

Los 16 GB de RAM y SSD de Plan de calidad pertenecen al equipo de referencia para rendimiento; no son un mínimo funcional demostrado. Se necesita Internet para obtener dependencias la primera vez. El funcionamiento posterior sin Internet sigue siendo el objetivo de PA26/PA32, no un resultado registrado.

Instalación local reproducible

Desde la raíz del repositorio:

```
pnpm install --frozen-lockfile

powershell -NoProfile -ExecutionPolicy Bypass -File .\scripts\Install-Database.ps1 `
-AdminServerInstance '.\SQLEXPRESS' `
-ApplicationServer '127.0.0.1' `
-ApplicationPort 1433 `
-DatabaseName 'SecureFinanceERP' `
-ApiLoginName 'SecureFinanceApi'
```

Para una base nueva, si se omiten `ApiSqlPassword` y `BootstrapPassword`, el helper genera valores aleatorios. La secuencia implementada es:

1. `database/install.sql`: base, esquema, funciones, SP, triggers, rol y permisos;
2. `database/provision-api-login.sql`: login/usuario SQL y pertenencia exclusiva a `SecureFinanceApiExecutor`;
3. `database/provision-bootstrap-admin.sql`: primer administrador con cambio obligatorio;
4. opcionalmente `database/seed-demo.sql`, solo con `-IncludeDemoData` y un nombre terminado en `_Test`;
5. `.env` y, para una cuenta bootstrap nueva, `secrets/first-access.txt` con intento de ACL restringida al usuario actual.

No copie a evidencia ni al repositorio `.env`, `secrets/`, `private-mailbox/`, contraseñas o tokens. Revise cualquier advertencia de ACL y elimine `secrets/first-access.txt` después de entregar la credencial por un canal privado y completar el primer cambio de contraseña.

El helper no modifica una base existente sin `-AllowExisting`. En ese modo exige la contraseña SQL conocida mediante `-ApiSqlPassword` como `SecureString`, no recupera secretos y no restablece una cuenta bootstrap existente. Haga copia previa y trate cualquier cambio de esquema como migración administrativa; que los scripts sean reejecutables no sustituye un plan de migración.

Para desarrollo:

```
pnpm dev
```

Abra `http://127.0.0.1:5173`. Para ejecución integrada de un solo origen:

```
pnpm build
pnpm start
```

Abra `http://127.0.0.1:3000`. Los valores predeterminados son HTTP local, cookie no `Secure`, certificado SQL confiado explícitamente y buzón de recuperación en archivo; son elecciones de laboratorio, no una configuración productiva.

Comprobaciones posteriores y su alcance

```
pnpm lint
pnpm test
pnpm build
pnpm sql:verify
pnpm test:e2e
$env:RUN_SQL_INTEGRATION='true'; pnpm test:integration; Remove-Item Env:RUN_SQL_INTEGRATION
pnpm test:smoke
pnpm test:e2e:private
```

- `lint`, `Vitest` y `build` comprueban calidad estática, pruebas aisladas y compilación según las suites presentes.
- `sql:verify` usa `.env` y ejecuta únicamente `dbo.sp_VerificarEstado` con la cuenta API.
- `test:e2e` ejecuta únicamente el humo público descrito arriba con sesión simulada y Microsoft Edge; no usa el login, la API integrada ni la base real.
- `test:integration`, `test:smoke` y `test:e2e:private` requieren la base `_Test` preparada. El humo crea datos sintéticos y guarda las credenciales vigentes bajo `secrets/`; el recorrido privado no escribe credenciales, cookies, trazas ni vídeo.
- Las pruebas de `database/tests/` se ejecutan expresamente contra una base `_Test` con una cuenta administrativa y conservando salida/código de retorno. Su mera presencia no cambia el estado PA.

Índice

Documento	Contenido
Este README	Estado real, requisitos, instalación y huecos de verificación.
Arquitectura	Componentes, límites de confianza, flujos y ejecución local.
ERD físico	Entidades, claves, relaciones, restricciones e índices principales.
Catálogo SQL	Tipos, funciones, procedimientos, triggers y permisos.
Contratos API	Autenticación, errores, paginación y endpoints HTTP.

Documento	Contenido
Decisiones técnicas	Seguridad, SHA2_512 académico, sesiones, TVP, importes y auditoría.
Trazabilidad	UC → pantalla → endpoint → procedimiento → PA.
Manual de usuario	Operación por módulo, temas Claro/Oscuro/Sistema y resolución de estados.
Respaldo y restauración	Copias, retención, restauración aislada y acta RPO/RTO.
Matriz PA01–PA32	Escenario, resultado esperado y campos de ejecución.
Plan QC01–QC08	Dataset, mediciones, percentiles y criterios de calidad.
Guion de demostración	Recorrido cronometrado de doce minutos.
Guía de evidencia	Capturas, registros, redacción y manifiesto verificable.
Verificación técnica ejecutada	Comprobaciones parciales observadas en el entorno local, sin cambiar el estado PA/QC.

Convenciones

- Fechas almacenadas: UTC; presentación: dd/mm/aaaa , hora de 24 horas en America/Guatemala para la configuración de demostración.
- Moneda de demostración: GTQ , siempre con código y dos decimales.
- Los importes viajan por HTTP como cadenas decimales; SQL Server conserva DECIMAL(19,2) .
- Identificadores de correlación: UUID en X-Correlation-Id y en las respuestas de error.
- Los ejemplos que contienen nombres de servidor, rutas o cuentas son marcadores y deben adaptarse sin incluir secretos.

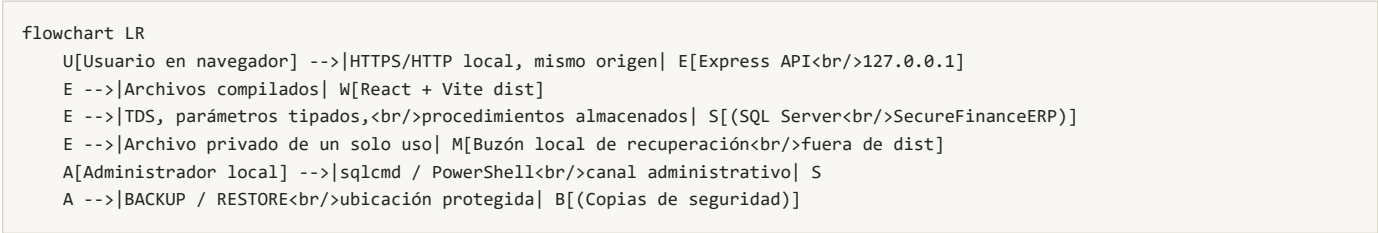
Arquitectura

Objetivo y alcance

SecureFinance ERP es una aplicación web local de un solo origen para autenticación, perfiles, ventas, productos, clientes, reportes, usuarios, roles y auditoría. La interfaz nunca abre conexiones a SQL Server. La API de Express es el único canal de operación de la aplicación y solo ejecuta procedimientos almacenados con parámetros tipados. La instalación, migración, respaldo y restauración usan un canal administrativo separado.

Quedan fuera del alcance devoluciones, anulaciones, compras, contabilidad general, múltiples sucursales y facturación electrónica.

Topología local



Límites de confianza

1. **Navegador no confiable.** Puede alterar rutas, cuerpos, precios, identificadores y permisos visibles. La API y SQL vuelven a validar identidad, propiedad, versión y autorización.
2. **API de aplicación.** Posee una cuenta SQL de mínimo privilegio. No instala objetos, no ejecuta DDL y no realiza DML directo.
3. **Base de datos.** Es la autoridad para sesiones, permisos, precios, IVA, stock, idempotencia, transacciones y auditoría.
4. **Canal administrativo.** Instala/migra objetos, crea el login mínimo, prepara el primer administrador y opera copias. No se expone por HTTP.
5. **Buzón de recuperación.** Es privado, local y ajeno al directorio público; el endpoint nunca devuelve el token.

Componentes

Componente	Responsabilidad	No debe hacer
apps/web	SPA React, rutas, accesibilidad, estados, temas y consumo de <code>/api</code> .	Conectarse a SQL, decidir permisos definitivos o calcular importes contables autoritativos.
apps/api	Contrato HTTP, esquema de entrada, cookies, CSRF, correlación, autorización y adaptación de recordsets.	Ejecutar DDL/DML directo, confiar en <code>UsuarioId</code> del cliente o revelar errores SQL.
database	Esquema, reglas, SP, TVP/TVF, transacciones, permisos y auditoría.	Confiar en precios/actor enviados por el navegador o sembrar datos al arrancar la API.
Pruebas distribuidas en <code>apps/*</code> , <code>database/tests</code> y <code>tests</code>	Vitest, integración con la identidad SQL real, humo HTTP, Playwright público/privado y scripts SQL; sigue sin existir arnés de carga de cinco sesiones.	Sustituir SQL Server por mocks para afirmar ACID, TVP, carreras o restauración.
docs	Operación, contratos, trazabilidad y evidencia.	Marcar una PA aprobada por inspección de código.

Ejecución

Desarrollo

- Vite escucha únicamente en `127.0.0.1` y reenvía `/api` a Express.
- Express escucha únicamente en `127.0.0.1`.
- `pnpm dev` inicia web y API; SQL Server debe estar activo y preparado.

Inicio integrado

1. `pnpm build` compila `apps/web/dist`.
2. `pnpm start` inicia Express.
3. Express sirve `/api/*` y, bajo el mismo origen, los archivos compilados y el fallback de la SPA.
4. El diseño no usa CDN ni servicios externos en runtime. La operación sin Internet es un objetivo de PA26/PA32 aún Pendiente; Playwright usa el Microsoft Edge instalado localmente y no descarga un navegador durante la prueba.

Flujo de una solicitud protegida

```
sequenceDiagram
    participant B as Navegador
    participant A as Express
    participant D as SQL Server
    B->>A: Solicitud + cookie HttpOnly + CSRF si modifica estado
    A->>A: Origen, JSON estricto y CorrelationId
    A->>D: sp_ValidarSesionApi(hash, IP, touch)
    D-->>A: usuario, vigencia, roles y permisos actuales
    A->>A: cambio obligatorio / permiso / CSRF
    A->>D: procedimiento funcional + SesionHash + IP + CorrelationId
    D->>D: valida actor y establece contexto de auditoría
    D->>D: operación transaccional/autorizada
    D-->>A: recordsets públicos
    A-->>B: JSON o error español + CorrelationId
```

Las consultas automáticas que solo comprueban sesión o apariencia deben usar `touch=false` para no prolongar artificialmente los 30 minutos de inactividad. La duración absoluta es de ocho horas.

Autenticación y autorización

- Sesión opaca aleatoria; en SQL se guarda únicamente su digest SHA-512.
- Cookie `HttpOnly`, `SameSite=Strict`, `Path=/`; `Secure` cuando el origen sea HTTPS.
- CSRF de encabezado para métodos que cambian estado y comprobación de mismo origen.
- Cinco fallos en quince minutos se limitan por cuenta e IP en SQL; el límite HTTP general es complementario.
- Cada operación protegida vuelve a comprobar vigencia, usuario activo, revocación y permisos desde SQL.
- Ocultar navegación mejora la UX, pero no concede ni retira autoridad.
- Una sesión con cambio inicial obligatorio solo accede a cambio de contraseña, apariencia local y cierre.

Política base de roles

Perfil	Capacidades iniciales
Administrador bootstrap	<code>provision-bootstrap-admin.sql</code> asigna los permisos activos de administración, catálogos, reportes y auditoría, pero excluye <code>VENTAS_CREAR</code> ; vender exige asignarlo explícitamente mediante otro rol.
Cajero	Crear ventas y consultar sus propias facturas.
Auditor	Consultar reportes y bitácoras; no modifica catálogos.
Sin roles	Perfil, seguridad, apariencia y cierre de sesión, sin funciones de negocio.

El nombre del rol no sustituye la comprobación de permisos efectivos. `REPORTES_LEER` permite consultar todas las facturas y métricas. Sin ese permiso, una consulta de factura exige propiedad de la venta.

Venta transaccional

1. El navegador envía cliente, producto/cantidad y solicita cotización.
2. SQL valida cliente/productos activos, obtiene precios y stock, agrupa el detalle y calcula subtotal e IVA.
3. El navegador confirma productos, cantidades, cliente, total aceptado como cadena y UUID de idempotencia.
4. SQL serializa la clave por usuario, compara la huella canónica y ejecuta encabezado, detalle, stock, caja y auditoría en una transacción con `XACT_ABORT` y `TRY/CATCH`.
5. Misma clave y contenido devuelve la misma factura; contenido distinto produce `409 IDEMPOTENCY_CONFLICT`.
6. Ante una respuesta incierta, el borrador conserva la clave y consulta el resultado. No genera otra venta ni otra clave hasta resolverlo.

El comprobante usa las instantáneas históricas de cliente, cajero, moneda, impuesto, producto y precio. Consultar o imprimir no registra otra venta.

Datos, tiempo e importes

- Autoridad contable: `DECIMAL(19,2)` en SQL.
- Transporte: cadenas con exactamente dos decimales; nunca `Number` como fuente contable.
- IVA académico: `ROUND(subtotal * 0.12, 2)` una sola vez en el encabezado.
- Fechas persistidas en UTC. Los filtros de día se convierten en el servidor a intervalos UTC correctos para la zona configurada.
- Paginación en servidor: 10, 25 o 50 filas, 25 por defecto; orden estable con desempate por clave.

Auditoría y pool

La identidad de aplicación proviene de la sesión. Cada SP protegido establece contexto de auditoría en la misma conexión que modifica datos y lo limpia incluso al fallar. Las pruebas deben alternar cuentas sobre un pool reutilizado para demostrar que no queda contexto residual.

- Accesos: resultado, motivo interno, principal SQL e IP observada.
- DML: triggers por conjuntos, una entrada por fila afectada; un rollback no deja auditoría DML de la transacción revertida.

- DDL: trigger de base para cambios de esquema por el canal administrativo.
- Nunca se registran contraseñas, hashes, salts, tokens, cookies ni cadenas de conexión.

Disponibilidad y fallos

Estado	Presentación/contrato
Carga	Indicador contextual; no tabla vacía temporal.
Sin registros	Mensaje válido y acción siguiente.
Sin coincidencias	Conserva filtros y permite limpiarlos.
Validación	Señala campos y conserva valores no sensibles.
Conflicto	409 , solicita actualizar o explica idempotencia/stock.
Sesión	401 , limpia datos sensibles y vuelve a acceso.
Prohibición	403 , sin revelar datos.
Servicio/SQL	503 , nunca se presenta como total cero o venta revertida confirmada.

ERD físico

Este modelo corresponde al esquema `dbo` declarado por los scripts de `database/`. El diagrama muestra columnas físicas, claves y relaciones declarativas; los campos de auditoría sin clave foránea se describen después del diagrama. `rowversion` se representa como `binary8` porque Mermaid no admite todos los tipos de SQL Server.

erDiagram

```
Permiso {
    int PermisoId PK
    varchar60 Codigo UK
    nvarchar120 Nombre
    varchar40 Modulo
    bit Activo
    datetime2 CreadoUtc
    datetime2 ActualizadoUtc
    binary8 VersionFila
}

Rol {
    int RolId PK
    varchar60 Nombre UK
    nvarchar250 Descripcion
    bit EsAdministrador
    bit Activo
    datetime2 CreadoUtc
    datetime2 ActualizadoUtc
    binary8 VersionFila
}

Usuario {
    int UsuarioId PK
    varchar50 NombreUsuario UK
    nvarchar120 NombreVisible
    nvarchar254 CorreoRecuperacion
    varbinary64 PasswordHash
    varbinary32 PasswordSalt
    bit DebeCambiarPassword
    bit Activo
    int VersionSeguridad
    datetime2 CreadoUtc
    datetime2 ActualizadoUtc
    datetime2 UltimoCambioPasswordUtc
    binary8 VersionFila
}

Usuario_Rol {
    int UsuarioId PK,FK
    int RolId PK,FK
    datetime2 AsignadoUtc
    int AsignadoPorUsuarioId FK
}

Rol_Permiso {
    int RolId PK,FK
    int PermisoId PK,FK
    datetime2 AsignadoUtc
    int AsignadoPorUsuarioId FK
}

Sesion {
    bigint SesionId PK
    varbinary64 SesionHash UK
    int UsuarioId FK
    int VersionSeguridad
    smallint MinutosInactividad
    datetime2 CreadaUtc
    datetime2 UltimaActividadUtc
    datetime2 ExpiraInactividadUtc
    datetime2 ExpiraAbsolutaUtc
    datetime2 RevocadaUtc
    varchar45 DireccionIP
    nvarchar300 AgenteUsuario
    uniqueidentifier CorrelationId
}

TokenRecuperacion {
    bigint TokenRecuperacionId PK
    int UsuarioId FK
    varbinary64 TokenHash UK
    datetime2 CreadoUtc
    datetime2 ExpiraUtc
    datetime2 UsadoUtc
    datetime2 RevocadoUtc
}
```

```

        varchar45 DireccionIP
        uniqueidentifier CorrelationId
    }
    PreferenciaUsuario {
        int UsuarioId PK,FK
        varchar10 Tema
        datetime2 ActualizadoUtc
        binary8 VersionFila
    }
    UnidadMedida {
        varchar20 Codigo PK
        nvarchar80 Nombre
        bit Activo
    }
    ConfiguracionSistema {
        tinyint ConfiguracionId PK
        char3 MonedaCodigo
        nvarchar64 ZonaHorariaIana
        sysname ZonaHorariaSql
        decimal TasaIVA
        datetime2 ActualizadoUtc
        binary8 VersionFila
    }
    Cliente {
        int ClienteId PK
        varchar30 Identificador UK
        nvarchar120 Nombre
        nvarchar254 Correo
        nvarchar30 Telefono
        bit Activo
        datetime2 CreadoUtc
        datetime2 ActualizadoUtc
        binary8 VersionFila
    }
    Producto {
        int ProductoId PK
        varchar30 Codigo UK
        nvarchar160 Descripcion
        varchar20 Unidad FK
        decimal Precio
        int Stock
        bit Activo
        datetime2 CreadoUtc
        datetime2 ActualizadoUtc
        binary8 VersionFila
    }
    MovimientoInventario {
        bigint MovimientoInventarioId PK
        int ProductoId FK
        int Variacion
        int StockAnterior
        int StockNuevo
        nvarchar250 Motivo
        int UsuarioId FK
        datetime2 FechaUtc
        uniqueidentifier CorrelationId
    }
    Factura {
        bigint FacturaId PK
        bigint Numero UK
        varchar20 Estado
        int ClienteId FK
        varchar30 ClienteIdentificador
        nvarchar120 ClienteNombre
        int UsuarioId FK
        nvarchar120 CajeroNombre
        datetime2 FechaUtc
        char3 Moneda
        decimal TasaIVA
        decimal Subtotal
        decimal IVA
        decimal Total
    }

```

```

        uniqueidentifier ClaveIdempotencia
        varbinary32 HuellaContenido
        uniqueidentifier CorrelationId
    }
Detalle_Factura {
    bigint DetalleFacturaId PK
    bigint FacturaId FK
    int ProductoId FK
    varchar30 ProductoCodigo
    nvarchar160 ProductoDescripcion
    varchar20 Unidad
    int Cantidad
    decimal PrecioUnitario
    decimal Importe
}
MovimientoCaja {
    bigint MovimientoCajaId PK
    bigint FacturaId FK,UK
    varchar20 Tipo
    decimal Importe
    char3 Moneda
    int UsuarioId FK
    datetime2 FechaUtc
}
Bitacora_Acceso {
    bigint BitacoraAccesoId PK
    datetime2 FechaUtc
    varchar254 NombreUsuarioIntentado
    int UsuarioId FK
    varchar30 Resultado
    nvarchar250 MotivoInterno
    varchar45 DireccionIP
    nvarchar300 AgenteUsuario
    nvarchar128 PrincipalSql
    nvarchar128 HostName
    nvarchar128 AppName
    uniqueidentifier CorrelationId
}
Bitacora_Transacciones {
    bigint BitacoraTransaccionId PK
    datetime2 FechaUtc
    sysname Tabla
    varchar10 Operacion
    nvarchar200 RegistroId
    int UsuarioAplicacionId
    varchar50 UsuarioAplicacion
    nvarchar128 PrincipalSql
    nvarchar128 HostName
    nvarchar128 AppName
    varchar45 DireccionIP
    uniqueidentifier CorrelationId
    nvarchar250 Motivo
    nvarcharmax ValoresAnteriores
    nvarcharmax ValoresNuevos
}
Bitacora_DDL {
    bigint BitacoraDDLId PK
    datetime2 FechaUtc
    sysname TipoEvento
    sysname TipoObjeto
    sysname NombreObjeto
    sysname Esquema
    nvarcharmax Comando
    nvarchar128 PrincipalSql
    varchar50 UsuarioAplicacion
    nvarchar128 HostName
    nvarchar128 AppName
    uniqueidentifier CorrelationId
    xml DatosEvento
}
Bitacora_Incidente {
    bigint BitacoraIncidenteId PK

```

```

    datetime2 FechaUtc
    varchar80 Operacion
    int UsuarioId
    uniqueidentifier CorrelationId
    int NumeroError
    nvarchar500 MensajeSanitizado
    nvarchar128 PrincipalSql
    nvarchar128 HostName
    nvarchar128 AppName
}
SchemaMigration {
    varchar100 MigrationId PK
    nvarchar250 Descripcion
    datetime2 AplicadaUtc
    sysname AplicadaPor
}

Usuario ||--o{ Usuario_Rol : recibe
Rol ||--o{ Usuario_Rol : agrupa
Rol ||--o{ Rol_Permission : concede
Permiso ||--o{ Rol_Permission : integra
Usuario ||--o{ Sesion : abre
Usuario ||--o{ TokenRecuperacion : solicita
Usuario ||--o{ PreferenciaUsuario : configura
UnidadMedida ||--o{ Producto : clasifica
Producto ||--o{ MovimientoInventario : registra
Usuario ||--o{ MovimientoInventario : ejecuta
Cliente ||--o{ Factura : identifica
Usuario ||--o{ Factura : procesa
Factura ||--|{ Detalle_Factura : contiene
Producto ||--o{ Detalle_Factura : referencia
Factura ||--|{ MovimientoCaja : genera
Usuario ||--o{ MovimientoCaja : registra
Usuario o||--o{ Bitacora_Acceso : relaciona

```

Relaciones y datos históricos

- Usuario_Rol** y **Rol_Permission** tienen clave primaria compuesta. **AsignadoPorUsuarioId** es opcional y referencia **Usuario**; el diagrama omite esas dos líneas autorreferentes para conservar legibilidad.
- PreferenciaUsuario** usa **UsuarioId** como PK y FK: una cuenta tiene cero o una fila; la lectura resuelve **sistema** cuando aún no existe.
- Factura** conserva instantáneas de identificador/nombre del cliente y nombre del cajero. **Detalle_Factura** conserva código, descripción, unidad y precio. Las FK permiten trazabilidad, pero las impresiones históricas no vuelven a leer esos textos desde el catálogo actual.
- UQ_Factura_Usuario_Clave** (**UsuarioId**, **ClaveIdempotencia**) impide duplicar una venta por cuenta. **HuellaContenido** distingue un reintento idéntico de una reutilización conflictiva.
- UQ_DetalleFactura_Factura_Producto** limita una línea por producto y **UQ_MovimientoCaja_Factura** un movimiento de caja por factura.
- Bitacora_Transacciones.UsuarioAplicacionId** y **Bitacora_Incidente.UsuarioId** son datos de evidencia, no FK. Esto evita que cambios de seguridad o mantenimiento del catálogo rompan el registro. **Bitacora_DDL** tampoco depende de tablas de negocio.
- ConfiguracionSistema** es una fila única (**ConfiguracionId** = 1) con moneda, zonas horarias e IVA. **SeqNumeroFactura** asigna el número comercial; los huecos de secuencia tras rollback son válidos y no representan facturas perdidas.
- SchemaMigration** registra la línea base/migraciones aplicadas por el canal administrativo; no participa en operaciones HTTP.

Restricciones físicas relevantes

Área	Regla de base de datos
Usuario	NombreUsuario ASCII permitido, 3–50; salt de 32 bytes; hash de 64 bytes; VersionSeguridad > 0.
Contraseña	Política validada por función: 12–128 caracteres, mayúscula, minúscula, número y símbolo.
Sesión	hash único de 64 bytes; inactividad 5–1440 minutos; vencimiento por inactividad no supera el absoluto.
Tema	claro , oscuro o sistema .
Cliente	identificador 1–30, nombre 2–120; identificador único.
Producto	código 1–30, descripción 2–160, precio 0.01–999999.99, stock 0–2147483647; unidad referenciada.
Inventario	variación entera distinta de cero, motivo 10–250, stock anterior/nuevo no negativo.
Factura	solo estado Confirmada ; dinero DECIMAL(19,2); Total = Subtotal + IVA ; huella de 32 bytes.
Detalle	cantidad 1–9999; importe igual a cantidad por precio exacto.
Caja	tipo único INGRESO_VENTA ; importe positivo.

Área	Regla de base de datos
Auditoría	operación DML INSERT , UPDATE o DELETE ; imágenes anterior/nueva, si existen, son JSON válido.

Índices principales

Índice	Finalidad
IX_Sesion_Usuario_Vigencia	Resolver/revocar sesiones de una cuenta por vigencia.
IX_TokenRecuperacion_Usuario_Vigencia	Resolver tokens activos y revocar los anteriores.
IX_Producto_Descripcion	Búsqueda/paginación de productos con columnas de presentación incluidas.
IX_Cliente_Nombre	Búsqueda/paginación de clientes con contacto/estado incluidos.
IX_Factura_Fecha	Reportes cronológicos y totales por rango.
IX_Factura_Usuario_Fecha	Facturas propias por usuario y fecha.
IX_BitacoraAcceso_Fecha	Consulta de accesos por fecha.
IX_BitacoraTransacciones_Fecha	Consulta de auditoría DML por fecha.
IX_BitacoraDDL_Fecha	Consulta de auditoría DDL por fecha.

Las restricciones e índices anteriores son diseño inspeccionado; su comportamiento se valida mediante PA/QC y permanece **Pendiente** hasta ejecutar la base real.

Decisiones técnicas

Las decisiones siguientes son reversibles salvo las reglas funcionales impuestas por la especificación. “Aceptada” significa que guía esta implementación; no equivale a certificación de seguridad o producción.

DT01 — JavaScript y workspace pnpm

Estado: aceptada.

El repositorio usa JavaScript moderno `.js/.jsx`, ESM y un workspace pnpm con `apps/web` y `apps/api`. Las versiones se fijan exactamente y `pnpm-lock.yaml` es la única fuente de resolución. No se generan `package-lock.json` ni `yarn.lock`.

DT02 — SPA y API bajo un mismo origen

Estado: aceptada.

Vite se usa en desarrollo con proxy; en ejecución integrada Express sirve el frontend compilado. Esto permite cookie de mismo sitio, elimina CORS abierto y simplifica CSRF. Ambos servicios se enlazan a loopback, nunca a `0.0.0.0` por defecto.

DT03 — SQL Server como frontera de integridad

Estado: aceptada y obligatoria.

La API ejecuta procedimientos almacenados; las TVF se consumen dentro de procedimientos. La cuenta de aplicación no recibe DML directo, DDL, `db_owner` ni `sysadmin`. Instalación y migración pertenecen a una cuenta administrativa y nunca se ejecutan al arrancar el servicio.

DT04 — Sesión opaca, cookie y CSRF

Estado: aceptada.

La cookie contiene un token aleatorio opaco. SQL conserva solo `SHA2_512(token)`. En cada operación se validan usuario activo, revocación, inactividad de 30 minutos, duración absoluta de ocho horas y permisos actuales. El token CSRF se deriva con HMAC-SHA-256 y se compara en tiempo constante; los métodos de escritura también validan el origen.

No se almacenan credenciales ni sesiones en `localStorage`. Al finalizar una sesión se eliminan token CSRF, datos privados y borradores sensibles en memoria.

DT05 — Perfil académico de contraseñas SHA2_512

Estado: aceptada por requisito académico, con riesgo explícito.

SQL genera un salt criptográfico individual y calcula `HASHBYTES('SHA2_512', salt + representación inequívoca de la contraseña)`. La contraseña conserva exactamente los 12–128 caracteres recibidos: no se recorta, normaliza ni trunca. La contraseña en claro atraviesa navegador y API para llegar al parámetro SQL, pero no se persiste, registra ni devuelve; hash y salt permanecen en tablas SQL y tampoco se proyectan por la API ni se incluyen en auditoría.

SHA2_512 es rápido y **no es un verificador de contraseña con factor de trabajo**. Esta decisión satisface la rúbrica académica, pero no convierte al sistema en “listo para producción”. Antes de una publicación real se requiere una migración versionada a Argon2id, scrypt, bcrypt o PBKDF2 con parámetros vigentes, rehash progresivo, pruebas de compatibilidad y plan de reversión.

DT06 — Recuperación de un solo uso

Estado: aceptada.

La API genera un token aleatorio, SQL guarda su digest, su vigencia es de 15 minutos y el consumo es atómico. La respuesta pública siempre es genérica. El token solo se entrega mediante un buzón local privado fuera de `apps/web/dist`. Cambiar o restablecer contraseña revoca sesiones y tokens anteriores.

DT07 — Parámetros tipados, TVP y permisos mínimos

Estado: aceptada y obligatoria.

`mssql` declara explícitamente longitud, precisión y tipo de cada parámetro. El detalle de una venta viaja como `dbo.TVP_DetalleFactura`; el navegador nunca genera SQL.

La cuenta API necesita, además de `EXECUTE` sobre los SP autorizados, permisos sobre el tipo concreto:

```
GRANT EXECUTE ON TYPE::dbo.TVP_DetalleFactura TO SecureFinanceApiExecutor;
GRANT REFERENCES ON TYPE::dbo.TVP_DetalleFactura TO SecureFinanceApiExecutor;
```

No se concede `EXECUTE` o `REFERENCES` indiscriminado a todos los tipos o a toda la base. `SecureFinanceApiExecutor` es el rol de base; el login/usuario concreto se aprovisiona por variables SQLCMD privadas y se agrega solo a ese rol.

DT08 — Importes exactos

Estado: aceptada.

SQL usa `DECIMAL(19,2)`. El HTTP usa cadenas decimales y la API valida formato y rango. Tediuous materializa `DECIMAL/NUMERIC` como `Number`, por lo que los SP de consulta proyectan importes públicos como texto con dos decimales. La interfaz puede usar aritmética decimal explícita para presentación, pero la cotización y confirmación autoritativas siempre proceden de SQL.

Casos de control obligatorios:

- `100.00` → IVA `12.00` → total `112.00`.
- `0.05` → IVA `0.01` → total `0.06`.

DT09 — Idempotencia de venta

Estado: aceptada.

La clave es un UUID ligado al usuario y a una huella canónica de cliente/productos/cantidades/total aceptado. Existe unicidad por usuario y clave. Solicitudes concurrentes de la misma clave se serializan. Una clave repetida con la misma huella recupera la factura; con otra huella devuelve conflicto.

Un error de transporte o `5xx` no prueba rollback. La API responde “resultado desconocido”, conserva la clave y consulta `sp_ConsultarResultadoVenta` hasta obtener un estado definitivo.

DT10 — Transacción de venta y fallos de prueba

Estado: aceptada.

Factura, detalle, descuento de stock, movimiento de caja y auditoría DML comparten una transacción con `SET XACT_ABORT ON`, `TRY/CATCH`, `COMMIT` y `ROLLBACK`. El stock se bloquea/actualiza en orden estable. El código intenta registrar un incidente técnico después del rollback en una tabla separada; PA06 debe demostrar ambos efectos contra SQL Server.

`database/tests/04_sale-rollback-fault.sql` implementa un punto de fallo posterior al encabezado sin añadir ramas de prueba al SP: crea un trigger temporal y todos los fixtures dentro de una transacción externa; el `ROLLBACK` del procedimiento elimina ambos. El script exige conexión administrativa y nombre `_Test`, comprueba factura/detalle/caja/stock/auditoría/incidente y limpia el incidente técnico al terminar. Es evidencia automatizable de un punto, no autorización para marcar PA06 sin el acta completa. `03_save-transaction.sql` conserva únicamente su propósito didáctico.

DT11 — Contexto de auditoría por conexión

Estado: aceptada.

La API pasa hash de sesión, IP observada y correlación. SQL resuelve el actor desde la sesión y establece `SESSION_CONTEXT` en la misma conexión de la operación. El contexto se limpia antes de devolver la conexión al pool. El navegador no selecciona `UsuarioId`.

DT12 — Control de concurrencia optimista

Estado: aceptada.

Productos, clientes, usuarios y roles exponen una versión `rowversion`. Toda edición envía la versión leída; una versión obsoleta produce `409 STALE_VERSION`. El stock solo cambia mediante ajuste transaccional con motivo de 10–250 caracteres.

DT13 — Temas por navegador y por cuenta

Estado: aceptada.

La preferencia anónima pertenece al navegador; la autenticada se guarda en SQL. El cambio se aplica antes de persistir, se serializa y una respuesta antigua no puede revertir el último valor. Al salir se restaura la preferencia anónima. Una lectura de sincronización fallida conserva el valor actual y no sobrescribe la cuenta.

DT14 — Errores públicos y correlación

Estado: aceptada.

La API distingue `400`, `401`, `403`, `404`, `409`, `429` y `503`. Cada error usa mensaje en español, código estable y `correlationId`; nunca contiene texto SQL, stack ni secretos. Los registros internos conservan solo los datos técnicos necesarios y permiten seguir la misma correlación.

DT15 — SQL Server Express y continuidad

Estado: aceptada para el entorno local.

SQL Server Express no incluye SQL Server Agent. La política requiere programar la copia diaria con Task Scheduler y PowerShell/sqlcmd, conservar al menos siete copias protegidas y una en otro medio. El repositorio aporta scripts SQL y una guía, no una tarea ya instalada. Restaurar para pruebas usa primero otra base y jamás sobrescribe automáticamente la existente.

DT16 — Dependencias y operación sin Internet

Estado: aceptada.

Iconos, estilos y fuentes usados por la aplicación se sirven localmente; no hay CDN, analítica ni API externa declarada en el código. El repositorio incluye Playwright y suites pública/privada que usan el canal `msedge` instalado en el equipo, no un navegador empaquetado. Tras obtener las dependencias, el runtime **debe** funcionar sin Internet con API y SQL Server activos, pero ese objetivo continúa Pendiente hasta ejecutar PA26/PA32 en una copia limpia y desconectada.

Contratos de la API HTTP

Convenciones generales

- Base relativa: `/api` ; mismo origen que la SPA en ejecución integrada.
- Medios: solicitudes y respuestas JSON UTF-8, salvo `204 No Content` .
- El analizador acepta JSON estricto y limita el cuerpo a 256 KiB. Los esquemas rechazan propiedades no declaradas.
- La cookie de sesión es opaca, `HttpOnly` , `SameSite=Strict` , `Path=` / y `Secure` cuando se configura HTTPS. El cliente usa `credentials: include` .
- Toda respuesta incluye `X-Correlation-Id` . Se conserva un UUID v4 válido enviado por el cliente; en otro caso la API genera uno.
- Cada escritura autenticada exige `X-CSRF-Token` , obtenido en el acceso o en `GET /api/auth/session` . Los métodos no seguros también se limitan a los orígenes configurados.
- Fechas de filtro usan `YYYY-MM-DD` ; instantes de respuesta usan ISO 8601 UTC. Los importes se transportan como cadenas con exactamente dos decimales.
- `page` empieza en 1 y `pageSize` solo admite `10` , `25` o `50` ; el valor predeterminado es 25.

Envolventes

Éxito individual:

```
{
  "data": { "id": 42 }
}
```

Listado:

```
{
  "data": [],
  "meta": {
    "page": 1,
    "pageSize": 25,
    "total": 0,
    "totalPages": 0
  }
}
```

Error público:

```
{
  "error": {
    "code": "VALIDATION_ERROR",
    "message": "Revise los datos enviados.",
    "fields": { "lines.0.quantity": "Valor no válido" }
  },
  "correlationId": "00000000-0000-4000-8000-000000000000"
}
```

`fields` solo aparece en errores de validación que pueden asociarse con campos. No se devuelven mensajes SQL, trazas, cookies, hashes ni tokens privados.

Autorización

Código	Alcance
VENTAS_CREAR	Cotizar/procesar ventas, consultar facturas propias y catálogos activos.
REPORTES_LEER	Reporte, métricas y todas las facturas.
PRODUCTOS_GESTIONAR	Crear/editar productos y ajustar inventario.
CLIENTES_GESTIONAR	Crear/editar clientes.
AUDITORIA_LEER	Accesos, DML y DDL.
USUARIOS_GESTIONAR	Usuarios, roles asignados y credencial temporal.
ROLES_GESTIONAR	Roles y permisos.

La UI usa esta matriz para navegar, pero cada endpoint y cada SP vuelven a comprobarla. Una sesión marcada `mustChangePassword` solo puede consultar su sesión, cambiar contraseña y cerrar sesión.

Autenticación y sesión

Método y ruta	Acceso / protección	Entrada	Éxito	Procedimiento
POST /api/auth/login	Público; límite 60/15 min en HTTP más regla SQL	{username, password}; usuario ASCII 3–50, contraseña 1–128	200; usuario, permisos, roles, vencimientos, csrfToken y configuración regional; fija cookie	sp_AutenticarUsuario
GET /api/auth/session	Sesión; no renueva inactividad; permite cambio obligatorio	—	200; misma forma de sesión y nuevo csrfToken	sp_ValidarSesionApi
POST /api/auth/logout	Sesión + CSRF; permite cambio obligatorio	cuerpo omitido	204; revoca sesión y borra cookie aun si falla el cierre SQL	sp_CerrarSesion
POST /api/auth/recover	Público; límite HTTP	{identity} de 3–254	202; mensaje idéntico exista o no la cuenta	sp_SolicitarRecuperacion
POST /api/auth/reset	Público; límite HTTP	{token, newPassword}; token 32–256; política 12–128	200; mensaje de restablecimiento	sp_RestablecerPassword

El enlace de recuperación se escribe únicamente en el buzón privado configurado, fuera de dist; el token en claro no forma parte de la respuesta HTTP.

Cuenta y preferencias

Método y ruta	Acceso / protección	Entrada	Éxito	Procedimiento
GET /api/me	Sesión	—	200; perfil, permissions[] y roles[]	sp_ConsultarPerfil
GET /api/me/preferences	Sesión; no renueva inactividad	—	200; {theme}	sp_ObtenerPreferenciasUsuario
PUT /api/me/preferences	Sesión + CSRF	{theme}: claro, oscuro o sistema	200; preferencia persistida	sp_GuardarPreferenciasUsuario
PUT /api/me/password	Sesión + CSRF; permite cambio obligatorio	{currentPassword, newPassword}	200; revoca sesiones/tokens y borra cookie	sp_CambiarPassword

La contraseña nueva conserva los caracteres recibidos; no se recorta. Debe tener 12–128 caracteres, mayúscula, minúscula, número y símbolo.

Inicio

Método y ruta	Acceso	Entrada	Éxito	Procedimiento
GET /api/dashboard	Sesión	—	200; summary, shortcuts[], refreshedAt	sp_ObtenerResumenInicio

El resumen global solo debe contener datos cuando el actor posee REPORTES_LEER; los accesos directos proceden de permisos efectivos.

Productos e inventario

Parámetros comunes de lista: page, pageSize, search (≤160), status=all|active|inactive, sort=code|description|price|stock|updatedAt, direction=asc|desc.

Método y ruta	Permiso / protección	Entrada	Éxito	Procedimiento
GET /api/products	VENTAS_CREAR o PRODUCTOS_GESTIONAR	consulta común	200 listado paginado	sp_ListarProductos
GET /api/products/options	igual	—	200 unidades activas	sp_ListarUnidadesMedida
POST /api/products	PRODUCTOS_GESTIONAR + CSRF	{code, description, unit, price}	201 producto; stock inicial 0	sp_CrearProducto
PATCH /api/products/:id	PRODUCTOS_GESTIONAR + CSRF	subconjunto de {code, description, unit, price, active} y version obligatoria	200 producto actualizado	sp_ActualizarProducto
POST /api/products/:id/inventory	PRODUCTOS_GESTIONAR + CSRF	{delta, reason, version}; entero no cero, motivo 10–250, version=0x + 16 hex	200 stock/versión nuevos	sp_AjustarInventario

Límites autoritativos: código 1–30, descripción 2–160, precio 0.01–999999.99, unidad de catálogo y stock no negativo. Una versión obsoleta devuelve 409 STALE_VERSION.

Clientes

Lista: page, pageSize, search (≤160), status=all|active|inactive, sort=identifier|name|email|updatedAt, direction=asc|desc.

Método y ruta	Permiso / protección	Entrada	Éxito	Procedimiento
GET /api/customers	VENTAS_CREAR o CLIENTES_GESTIONAR	consulta de lista	200 listado paginado	sp_ListarClientes

Método y ruta	Permiso / protección	Entrada	Éxito	Procedimiento
POST /api/customers	CLIENTES_GESTIONAR + CSRF	{identifier, name, email?, phone?}	201 cliente	sp_CrearCliente
PATCH /api/customers/:id	CLIENTES_GESTIONAR + CSRF	subconjunto de {identifier, name, email, phone, active} y version	200 cliente actualizado	sp_ActualizarCliente

identifier admite 1–30, name 2–120, correo hasta 254 y teléfono hasta 30. Cadena vacía o null elimina los contactos opcionales; no borra facturas históricas.

Ventas y comprobantes

Una línea siempre tiene {productId: entero positivo, quantity: 1..9999}. Debe haber 1–100 productos distintos; no se aceptan precios enviados por el cliente.

Método y ruta	Permiso / protección	Entrada	Éxito	Procedimiento				
POST /api/sales/quote	VENTAS_CREAR + CSRF	{customerId, lines[]}	200 ; líneas valoradas y totales SQL	sp_CotizarVenta				
POST /api/sales	VENTAS_CREAR + CSRF	{customerId, lines[], acceptedTotal, idempotencyKey}	201 nueva; 200 reintento idéntico; factura resumida	sp_ProcesarVentaTransaccional				
GET /api/sales	VENTAS_CREAR o REPORTES_LEER	lista + from?, to?, `scope=mine	all , sort=date	number	customer	total`	200 facturas autorizadas	sp_ConsultarVentasProp
GET /api/sales/result/:key	VENTAS_CREAR	UUID de la clave	200 si resuelta; 202 {status:"pending", idempotencyKey} si aún no aparece	sp_ConsultarResultadoVenta				
GET /api/sales/:id	VENTAS_CREAR o REPORTES_LEER	id positivo	200 ; encabezado, lines[], cashMovement	sp_ConsultarFactura				

acceptedTotal usa cadena decimal exacta. Si ocurre un fallo técnico después de enviar la venta, POST /api/sales devuelve 503 SALE_RESULT_UNKNOWN : el cliente conserva la misma clave y usa el endpoint result ; no crea otra clave mientras el resultado sea incierto. Una clave ya usada con contenido diferente devuelve 409 IDEMPOTENCY_CONFLICT .

Un actor con VENTAS_CREAR solo puede consultar sus facturas. scope=all y acceso a facturas ajenas requieren REPORTES_LEER , incluso si el navegador altera la consulta.

Reportes y auditoría

Método y ruta	Permiso	Entrada	Éxito	Procedimiento				
GET /api/reports/sales	REPORTES_LEER	from, to , paginación, búsqueda, `sort=date	number	customer	cashier	total`, dirección	200 ; listado, meta.totals , meta.range	sp_ObtenerHistoricoVentas
GET /api/audit/access	AUDITORIA_LEER	paginación, búsqueda, fechas opcionales, orden	200 bitácora de acceso	sp_ConsultarBitacoraAcceso				
GET /api/audit/dml	AUDITORIA_LEER	igual	200 cambios DML	sp_ConsultarAuditoriaDML				
GET /api/audit/ddl	AUDITORIA_LEER	igual	200 cambios de esquema	sp_ConsultarAuditoriaDDL				

El rango de reporte contiene entre 1 y 366 días inclusivos (to - from de 0 a 365). Los totales corresponden al filtro completo, no solo a la página. Las categorías de auditoría son cerradas; cualquier otra categoría falla con 400 .

Usuarios, roles y permisos

Las listas aceptan paginación, búsqueda, sort=name|username|status|updatedAt y dirección. Las mutaciones requieren CSRF y version en actualizaciones.

Método y ruta	Permiso	Entrada	Éxito	Procedimiento
GET /api/users	USUARIOS_GESTIONAR	consulta de lista	200 usuarios y roles	sp_ListarUsuarios
POST /api/users	USUARIOS_GESTIONAR	{username, displayName, email?, roleIds[]}	201 ; usuario y contraseña temporal mostrada una vez	sp_CrearUsuario

Método y ruta	Permiso	Entrada	Éxito	Procedimiento
PATCH /api/users/:id	USUARIOS_GESTIONAR	subconjunto de {displayName, email, active, roleIds} + version	200 ; usuario; revoca sesiones si cambia seguridad	sp_ActualizarUsuario
POST /api/users/:id/reset-password	USUARIOS_GESTIONAR	{ } exacto	200 ; contraseña temporal mostrada una vez	sp_GenerarPasswordTemporal
GET /api/roles	ROLES_GESTIONAR	consulta de lista	200 roles y permisos	sp_ListarRoles
POST /api/roles	ROLES_GESTIONAR	{name, description?, permissions[]}	201 rol	sp_CrearRol
PATCH /api/roles/:id	ROLES_GESTIONAR	subconjunto de {name, description, active, permissions} + version	200 ; revoca sesiones afectadas al cambiar permisos	sp_ActualizarRol
GET /api/permissions	ROLES_GESTIONAR	—	200 catálogo activo	sp_ListarPermisos

username es ASCII 3–50; displayName 2–120; roleIds admite hasta 30 IDs. El nombre de rol mide 3–60 y la descripción HTTP hasta 200. La API genera la credencial temporal, la envía como parámetro tipado y solo la muestra en esa respuesta; debe entregarse por canal privado.

Estado de servicio

Método y ruta	Acceso	Éxito	Procedimiento
GET /api/health	Público local	200 ; {status, database, checkedAt}	sp_VerificarEstado

Este endpoint demuestra conectividad inmediata, no salud integral ni cumplimiento de QC.

Estados y códigos de error

HTTP	Código público frecuente	Uso
400	INVALID_JSON , VALIDATION_ERROR , INVALID_CREDENTIALS , RESET_INVALID	JSON/esquema/regla inválida; credenciales y recuperación no revelan detalles internos.
401	SESSION_REQUIRED , SESSION_INVALID	Sin cookie, sesión cerrada, vencida o revocada; la API borra la cookie.
403	CSRF_INVALID , ORIGIN_INVALID , FORBIDDEN , PASSWORD_CHANGE_REQUIRED	Origen/CSRF/permiso o restricción por cambio inicial.
404	NOT_FOUND , ROUTE_NOT_FOUND	Recurso o ruta inexistente.
409	CONFLICT , STALE_VERSION , IDEMPOTENCY_CONFLICT , INSUFFICIENT_STOCK	Conflicto de negocio o concurrencia.
429	RATE_LIMITED	Demasiados intentos o solicitudes.
503	DATABASE_UNAVAILABLE , SALE_RESULT_UNKNOWN	Base no disponible o resultado de venta aún no determinable.
500	INTERNAL_ERROR	Error no clasificado; mensaje sanitizado.

Los números SQL 51001–51012 se convierten a estos códigos. Los estados descritos son contratos de diseño inspeccionados; sus pruebas PA permanecen **Pendiente** hasta ejecución real.

Catálogo SQL

Instalación y convenciones

`database/install.sql` es el punto de entrada SQLCMD para **objetos de base**. Ejecuta, en orden, base/configuración, esquema, funciones, seguridad, catálogos, ventas/reportes, auditoría y permisos. `$(DatabaseName)` debe ser un identificador simple autorizado. No crea por sí solo el login SQL ni la cuenta bootstrap.

El punto de entrada recomendado para preparar un entorno local completo es `scripts/Install-Database.ps1`. Después de `install.sql`, ejecuta `provision-api-login.sql`, `provision-bootstrap-admin.sql` y, si se solicita para una base `_Test`, `seed-demo.sql`; finalmente genera la configuración local y la credencial inicial privada. La secuencia y los requisitos se detallan en README de documentación.

Los scripts pertenecen al canal administrativo; la API no instala, migra ni siembra objetos al arrancar. Reejecutar la línea base crea objetos ausentes y recompila código con `CREATE OR ALTER`, pero no constituye por sí mismo una migración completa de tablas preexistentes.

Inventario de la línea base

Clase	Declarados	Expuestos a la cuenta API
Procedimientos	41	36 mediante <code>GRANT EXECUTE</code> individual
Funciones	6	0 directas; se consumen dentro de SP
Tipos de tabla	4	3 (<code>TVP_DetalleFactura</code> , <code>TVP_ListaEnteros</code> , <code>TVP_CodigosPermiso</code>)
Triggers	11	0 directos; 10 DML y 1 DDL de base

Los cinco SP internos sin concesión a `SecureFinanceApiExecutor` son `sp_LimpiarContextoAuditoria`, `sp_RegistrarAcceso`, `sp_ResolverSesion`, `sp_ObtenerPermisosUsuario` y `sp_ValidarTokenRecuperacion`.

Abreviaturas usadas en las tablas:

- S:** `@SesionHash varbinary(64)`, `@DireccionIP varchar(45)=NULL`, `@CorrelationId uniqueidentifier=NULL`.
- P:** `@Pagina int=1`, `@TamanoPagina tinyint=25`, `@Busqueda nvarchar(160)=NULL`, más orden/dirección del módulo.
- Lista:** primer recordset de filas; segundo recordset `{page, pageSize, total, totalPages}`.
- Todos los procedimientos protegidos resuelven otra vez la sesión en SQL. Los permisos indicados son mínimos funcionales, no sustituyen los `GRANT` de la cuenta API.
- Los procedimientos de escritura usan parámetros tipados y devuelven errores `51001-51012` para que la API los transforme en errores públicos.

Tipos definidos por el usuario

Tipo	Columnas	Uso
<code>dbo.TVP_DetalleFactura</code>	<code>ProductoId int PK</code> , <code>Cantidad int CHECK 1..9999</code>	Cotización y venta; una fila por producto, máximo funcional 100.
<code>dbo.TVP_IdEntero</code>	<code>Id int PK</code>	Lista genérica de IDs; reservado por el esquema.
<code>dbo.TVP_ListaEnteros</code>	<code>Id int PK</code>	Roles asignados a un usuario.
<code>dbo.TVP_CodigosPermiso</code>	<code>Codigo varchar(50) PK</code>	Permisos asignados a un rol.

La API necesita `EXECUTE` y `REFERENCES` sobre cada tipo que envía. El rol real de base es `SecureFinanceApiExecutor`; para ventas, el requisito explícito es:

```
GRANT EXECUTE ON TYPE::dbo.TVP_DetalleFactura TO SecureFinanceApiExecutor;
GRANT REFERENCES ON TYPE::dbo.TVP_DetalleFactura TO SecureFinanceApiExecutor;
```

`07_permissions.sql` aplica ambas concesiones también a `TVP_ListaEnteros` y `TVP_CodigosPermiso`, porque la API los materializa para usuarios/roles. No se concede acceso genérico a todos los tipos.

Funciones

Función	Parámetros / retorno	Responsabilidad
<code>fn_CalcularSubtotal</code>	<code>(<@Cantidad int, @Precio decimal(19,2)> → decimal(19,2)</code>	Multiplica y redondea a dos decimales; usada por cotización/venta.
<code>fn_CalcularIVA</code>	<code>(<@Subtotal decimal(19,2)> → decimal(19,2)</code>	Lee <code>ConfiguracionSistema.TasaIVA</code> y redondea una vez el IVA de encabezado.
<code>fn_ContrasenaCumplePolitica</code>	<code>(<@Contrasena nvarchar(128)> → bit</code>	Exige 12–128, mayúscula, minúscula, número y símbolo sin recorte.
<code>fn_TienePermiso</code>	<code>(<@UsuarioId int, @Codigo varchar(60)> → bit</code>	Resuelve permisos mediante roles/permisos activos.
<code>fn_ObtenerHistoricoVentas</code>	<code>(<@FechaDesdeUtc datetime2(3), @FechaHastaExclusivaUtc datetime2(3)> → tabla</code>	Solo facturas <code>Confirmada</code> en intervalo UTC semiabierto.
<code>fn_ConsultarAuditoriaDML</code>	fechas UTC opcionales + búsqueda → tabla	Filtra la bitácora DML; la API la consume indirectamente mediante SP.

Las funciones tabulares no se exponen directamente a la cuenta HTTP; los procedimientos aplican permiso, zona horaria, paginación y proyección pública.

Seguridad, sesión y preferencias

Procedimiento	Parámetros propios además de S	Permiso / consumidor	Resultado y efecto	oscuro	sistema'; devuelve tema y fecha.
sp_LimpiarContextoAuditoria	ninguno	Interno	Limpia UsuarioId , usuario, IP, correlación y motivo de SESSION_CONTEXT en la conexión reutilizable.		
sp_RegistrarAcceso	usuario intentado/id, resultado, motivo, IP, agente, correlación	Interno	Inserta Bitacora_Acceso ; nunca recibe contraseña/hash/salt/token.		
sp_ResolverSesion	permiso opcional, permitir cambio obligatorio, actualizar actividad; tres OUTPUT	Interno, base de todos los SP protegidos	Valida sesión/cuenta/versiones/vencimientos/permiso, establece contexto y devuelve identidad.		
sp_ObtenerPermisosUsuario	@UsuarioId	Interno	Permisos y roles activos del usuario resuelto.		
sp_AutenticarUsuario	usuario, contraseña, hash de nueva sesión, agente, 30 min/8 h	Público desde login	Valida límite/estado/hash académico, registra acceso, crea sesión y devuelve usuario + permisos + roles.		
sp_ValidarSesionApi	S + @ActualizarActividad bit	Middleware	Usuario/sesión + permisos + roles; opcionalmente renueva inactividad sin superar vencimiento absoluto.		
sp_CerrarSesion	S	Cuenta propia	Marca la sesión revocada.		
sp_ConsultarPerfil	S	Cuenta propia	Perfil; segundo recordset permisos; tercero roles.		
sp_ObtenerPreferenciasUsuario	S	Cuenta propia	Tema vigente; lectura sin confiar en ID del cliente.		
sp_GuardarPreferenciasUsuario	@Tema varchar(10)	Cuenta propia	MERGE /actualiza `claro		
sp_CambiarPassword	contraseña actual/nueva	Cuenta propia; permitido durante cambio obligatorio	Salt/hash nuevos, incrementa versión, revoca sesiones y tokens; obliga a iniciar de nuevo.		
sp_SolicitarRecuperacion	identidad, hash del token, vigencia, IP/correlación	Público	Devuelve destino/vencimiento únicamente a la API cuando la cuenta es elegible; la API siempre emite la misma respuesta HTTP y escribe el enlace solo en el buzón privado.		
sp_ValidarTokenRecuperacion	hash del token	Interno, sin GRANT ni llamada desde la API actual	Indica token vigente sin devolver el secreto; queda disponible para diagnóstico administrativo controlado.		
sp_RestablecerPassword	hash del token, contraseña nueva, IP/correlación	Público con token	Consumes atómicamente una vez, cambia salt/hash y revoca sesiones/tokens.		

sp_ResolverSesion siempre se acompaña de sp_LimpiarContextoAuditoria en éxito y error. PA29 debe comprobar que una conexión del pool usada por otra cuenta no conserva actor residual.

Estado del servicio

Procedimiento	Parámetros	Consumidor	Resultado
sp_VerificarEstado	ninguno	GET /api/health	Una fila con estado de base, UTC de SQL, moneda y zona IANA. No requiere sesión y no expone configuración secreta.

Usuarios, roles y permisos

Procedimiento	Parámetros propios además de S	Permiso	Resultado / reglas
sp_ListarPermisos	—	ROLES_GESTIONAR	Catálogo activo ordenado por módulo/código.
sp_ListarUsuarios	P	USUARIOS_GESTIONAR	Lista usuarios y roles JSON; incluye estado, cambio obligatorio y rowversion .
sp_CrearUsuario	usuario, nombre visible, correo, contraseña temporal, TVP_ListaEnteros	USUARIOS_GESTIONAR	Crea cuenta, roles y preferencia sistema ; hash/salt se generan en SQL.
sp_ActualizarUsuario	id, campos opcionales, flags de cambio, roles TVP, versión	USUARIOS_GESTIONAR	Control optimista, protege último administrador y revoca sesiones al cambiar estado/roles.
sp_GenerarPasswordTemporal	usuario id, contraseña temporal	USUARIOS_GESTIONAR	Salt/hash nuevos, cambio obligatorio; revoca sesiones/tokens.
sp_ListarRoles	P	ROLES_GESTIONAR	Lista roles y permisos JSON con rowversion .
sp_CrearRol	nombre, descripción, TVP_CodigosPermiso	ROLES_GESTIONAR	Crea rol y asignaciones validadas.
sp_ActualizarRol	id, campos/flags opcionales, permisos TVP, versión	ROLES_GESTIONAR	Control optimista; protege rol administrador; al cambiar permisos incrementa versión de seguridad y revoca sesiones afectadas.

Catálogos

Procedimiento	Parámetros propios además de S	Permiso	Resultado / reglas
sp_ListarUnidadesMedida	—	VENTAS_CREAR o PRODUCTOS_GESTIONAR	Unidades activas.
sp_ListarProductos	P + estado	venta o gestión de productos	Lista con precio como texto, stock, estado, fecha y versión.
sp_CrearProducto	código, descripción, unidad, precio texto	PRODUCTOS_GESTIONAR	Valida catálogo/rango, crea con stock 0; código único.
sp_ActualizarProducto	id, campos opcionales, versión	PRODUCTOS_GESTIONAR	Actualización con rowversion ; no cambia stock.
sp_AjustarInventario	producto, variación, motivo, versión	PRODUCTOS_GESTIONAR	Bloqueo transaccional, stock en rango, MovimientoInventario y motivo en auditoría.
sp_ListarClientes	P + estado	venta o gestión de clientes	Lista con contacto, estado y versión.
sp_CrearCliente	identificador, nombre, correo, teléfono	CLIENTES_GESTIONAR	Crea cliente; identificador único.
sp_ActualizarCliente	id, campos/flags opcionales, versión	CLIENTES_GESTIONAR	Actualización optimista; cadena vacía puede limpiar contacto.

Todos los listados validan página >0 , tamaños 10/25/50 , valores cerrados de orden/estado y desempate por PK.

Ventas, comprobantes, reporte e inicio

Procedimiento	Parámetros propios además de S	Permiso	Recordsets / garantías	
sp_CotizarVenta	cliente, TVP_DetalleFactura	VENTAS_CREAR	1: líneas con precio/stock; 2: subtotal, tasa, IVA, total y moneda. Precios/IVA se leen de SQL.	
sp_ProcesarVentaTransaccional	cliente, detalle TVP, total aceptado texto, UUID	VENTAS_CREAR	Una fila de factura; replayed distingue alta/reintento. Serializa clave por usuario, bloquea productos en orden, recalcula, descuenta stock y crea factura/detalle/caja en una transacción.	
sp_ConsultarResultadoVenta	UUID	VENTAS_CREAR	Factura de esa clave y usuario o cero filas si aún no está resuelta.	
sp_ConsultarVentasPropias	P, fechas opcionales, alcance `mine	all'	venta propia; all requiere reportes	Lista y metadatos; fechas locales convertidas a intervalo UTC.
sp_ConsultarFactura	factura id	dueño con VENTAS_CREAR o REPORTES_LEER	1: encabezado histórico; 2: líneas; 3: movimiento de caja. Fuera de alcance responde como no encontrado.	
sp_ObtenerHistoricoVentas	fechas obligatorias + P	REPORTES_LEER	1: ventas; 2: metadatos; 3: totales de todo el filtro. Máximo 366 días.	
sp_ObtenerResumenInicio	—	sesión	1: resumen diario solo con reportes; 2: accesos rápidos por permiso.	

Atomicidad e idempotencia de sp_ProcesarVentaTransaccional

1. valida 1–100 filas y total textual exacto;
2. deriva actor de la sesión;
3. calcula huella SHA-256 canónica de cliente, total y detalle ordenado;
4. abre transacción y toma sp_getapplock exclusivo por usuario+UUID;
5. si existe la clave: misma huella devuelve la factura; huella distinta lanza 51008 ;
6. bloquea cliente/configuración y productos en orden de ProductoId ;
7. recalcula subtotal/IVA/total y comprueba stock/total aceptado;
8. descuenta stock e inserta encabezado, líneas y movimiento de caja;
9. confirma todo o revierte todo con XACT_ABORT / TRY...CATCH ;
10. tras rollback, registra Bitacora_Incidente solo para fallos técnicos no funcionales y limpia el contexto.

La secuencia de factura puede dejar huecos por rollback; la integridad se evalúa por filas persistidas, no por continuidad numérica.

Auditoría

Procedimiento	Parámetros propios además de S	Permiso	Resultado
sp_ConsultarBitacoraAcceso	P + fechas opcionales	AUDITORIA_LEER	Intento/actor, resultado, motivo interno, IP, principal SQL, host/app y correlación.
sp_ConsultarAuditoriaDML	P + fechas opcionales	AUDITORIA_LEER	Actor, objeto, operación, registro, contexto, motivo e imágenes JSON.
sp_ConsultarAuditoriaDDL	P + fechas opcionales	AUDITORIA_LEER	Evento/objeto/esquema/comando, principal, contexto y correlación.

Las fechas ingresadas son días locales y los SP las convierten a UTC semiabierto. La API proyecta solo estos SP; no concede SELECT directo sobre bitácoras.

Triggers

Trigger	Ámbito	Datos registrados
trg_Usuario_AuditoriaDML	Usuario I/U/D	Identidad visible, correo, cambio obligatorio, estado y versión de seguridad; excluye hash/salt.
trg_Rol_AuditoriaDML	Rol I/U/D	Nombre, descripción, indicador administrador y estado.
trg_UsuarioRol_AuditoriaDML	Usuario_Rol I/U/D	Par usuario/rol.
trg_RolPermiso_AuditoriaDML	Rol_Permiso I/U/D	Par rol/permiso.
trg_Producto_AuditoriaDML	Producto I/U/D	Catálogo, precio, stock y estado.
trg_Cliente_AuditoriaDML	Cliente I/U/D	Identificación, nombre, contacto y estado.
trg_Factura_AuditoriaDML	Factura I/U/D	Identidades referenciadas, moneda/tasa e importes; excluye clave/huella.
trg_DetalleFactura_AuditoriaDML	Detalle_Factura I/U/D	Factura/producto, cantidad, precio e importe.
trg_MovimientoCaja_AuditoriaDML	MovimientoCaja I/U/D	Factura, tipo, importe, moneda y usuario.
trg_PreferenciaUsuario_AuditoriaDML	PreferenciaUsuario I/U/D	Usuario y tema.
trg_SecureFinance_AuditoriaDDL	base, eventos DDL	EVENTDATA , comando, objeto, principal SQL, actor/contexto; evita autorregistrar su propia bitácora/trigger.

Los triggers DML son por conjuntos: unen `inserted` y `deleted` por PK y generan una fila de bitácora por registro afectado. Al ser parte de la transacción, un rollback también revierte su auditoría DML. PA09 verifica ambas propiedades.

Errores de dominio

SQL	Significado	HTTP esperado
51001	sesión inválida/vencida/revocada	401
51002	permiso insuficiente	403
51003	recurso no encontrado/fuera de alcance	404
51004	conflicto de negocio	409
51005	límite de intentos	429
51006	dato/filtro/configuración inválida	400
51007	cambio de contraseña obligatorio	403
51008	clave idempotente usada con otra huella	409
51009	<code>rowversion</code> obsoleta	409
51010	stock insuficiente/fuera de rango	409
51011	credenciales inválidas	400 genérico
51012	token de recuperación inválido/vencido/usado	400 genérico

Rol SQL y aprovisionamiento

`07_permissions.sql` crea `SecureFinanceApiExecutor` y aplica mínimo privilegio:

- `DENY SELECT, INSERT, UPDATE, DELETE ON SCHEMA::dbo ;`
- `DENY ALTER, CONTROL, TAKE OWNERSHIP ON SCHEMA::dbo ;`
- `GRANT EXECUTE` solo a los procedimientos públicos consumidos por la API, incluido `sp_VerificarEstado` ;
- no concede ejecución directa a los cinco SP internos inventariados arriba ni a funciones;
- `GRANT EXECUTE` y `GRANT REFERENCES` sobre los tres TVP enviados por `mssql` ;
- ninguna pertenencia a `db_owner` , `db_datareader` , `db_datawriter` o roles de servidor elevados.

`provision-api-login.sql` se ejecuta por separado en modo SQLCMD con `DatabaseName` , `ApiLoginName` y una contraseña privada de al menos 16 caracteres. Crea el login/usuario si no existe y lo agrega únicamente a `SecureFinanceApiExecutor` . La contraseña no se guarda en el repositorio ni en evidencia.

`SchemaMigration` registra `0001_baseline` , `0002_security_contract_hardening` y el principal administrativo que aplicó cada una. La segunda retira `VENTAS_CREAR` de roles administradores existentes, sanea texto DDL legado y refuerza contratos. Estas marcas confirman aplicación administrativa, no autorizan migraciones desde el arranque de Express ni sustituyen su ensayo previo.

Verificación del catálogo

La presencia de objetos puede inventariarse después de instalar, sin probar comportamiento:

```
SELECT s.name AS esquema, o.name, o.type_desc
FROM sys.objects AS o
JOIN sys.schemas AS s ON s.schema_id = o.schema_id
WHERE s.name = N'dbo'
      AND (o.name LIKE N'sp[_]%' OR o.name LIKE N'fn[_]%' OR o.name LIKE N'trg[_]%' )
ORDER BY o.type_desc, o.name;

SELECT s.name AS esquema, tt.name AS tipo_tabla
FROM sys.table_types AS tt
JOIN sys.schemas AS s ON s.schema_id = tt.schema_id
WHERE s.name = N'dbo'
ORDER BY tt.name;
```

database/tests/01_contract.sql automatiza el inventario y algunas firmas/reglas de la línea base; 02_pool_identity_pa29.sql comprueba limpieza básica de contexto; 03_save-transaction.sql demuestra savepoint; y 04_sale-rollback-fault.sql fuerza y verifica un rollback posterior al encabezado sin persistir fixtures. `pnpm sql:verify` ejecuta únicamente `sp_VerificarEstado` con la cuenta de aplicación, mientras la suite de integración comprueba denegaciones directas del mismo login. Ninguna comprobación aislada demuestra todas las carreras, autorización extremo a extremo o continuidad: PA01–PA32 permanecen **Pendiente** hasta una corrida completa con evidencia enlazada.

Trazabilidad funcional

Esta matriz enlaza la especificación funcional resumida con rutas React, operaciones HTTP y objetos SQL presentes en el código. Una relación indica cobertura estática de diseño/código; **no** significa que el recorrido funcione en runtime ni que una PA esté ejecutada. El estado oficial de todas las PA se conserva en Matriz PA01–PA32.

La flecha de trazabilidad es direccional: la expectativa UC/PA conduce a la implementación y después a la evidencia. La existencia de implementación no reemplaza la expectativa, y una prueba unitaria con dobles de SQL no reemplaza una corrida contra SQL Server real.

UC → pantalla → HTTP → SQL → PA

UC	Caso y pantalla/ruta	Endpoint(s)	Procedimiento(s) / función SQL	PA principales
UC01	Autenticación de usuario — /acceso	POST /api/auth/login; GET /api/auth/session	sp_AutenticarUsuario, sp_ValidarSesionApi, sp_RegistrarAcceso, sp_ObtenerPermisosUsuario	PA01, PA04, PA11, PA29
UC02	Cambio de contraseña segura e inicial obligatorio — /perfil/seguridad	PUT /api/me/password	sp_CambiarPassword, fn_ContrasenaCumplePolitica	PA02, PA11
UC03	Venta transaccional — /ventas/nueva, /ventas, /ventas/:id	POST /api/sales/quote; POST /api/sales; GET /api/sales; GET /api/sales/result/:key; GET /api/sales/:id	sp_CotizarVenta, sp_ProcesarVentaTransaccional, sp_ConsultarVentasPropias, sp_ConsultarResultadoVenta, sp_ConsultarFactura, fn_CalcularSubtotal, fn_CalcularIVA, TVP_DetalleFactura	PA05–PA10, PA22, PA25, PA28, PA30
UC04	Consulta de bitácoras y auditoría — /auditoria	GET /api/audit/access; GET /api/audit/dml; GET /api/audit/ddl	sp_ConsultarBitacoraAcceso, sp_ConsultarAuditoriaDML, sp_ConsultarAuditoriaDDL, fn_ConsultarAuditoriaDML; triggers DML y DDL	PA01, PA04, PA09, PA12, PA29
UC05	Recuperación/restablecimiento — /recuperar, /restablecer	POST /api/auth/recover; POST /api/auth/reset	sp_SolicitarRecuperacion, sp_RestablecerPassword, fn_ContrasenaCumplePolitica	PA03, PA11
UC06	Perfil y permisos propios — /perfil	GET /api/me; GET /api/me/preferences	sp_ConsultarPerfil, sp_ObtenerPermisosUsuario, sp_ObtenerPreferenciasUsuario	PA04, PA18, PA23, PA29
UC07	Roles y permisos — /roles	GET/POST/PATCH /api/roles; GET /api/permissions	sp_ListarRoles, sp_CrearRol, sp_ActualizarRol, sp_ListarPermisos, fn_TienePermiso	PA04, PA11, PA18, PA27
UC08	Productos, precios, estado e inventario — /productos	GET/POST/PATCH /api/products; GET /api/products/options; POST /api/products/:id/inventory	sp_ListarProductos, sp_ListarUnidadesMedida, sp_CrearProducto, sp_ActualizarProducto, sp_AjustarInventario; triggers DML	PA09, PA10, PA21, PA27, PA28
UC09	Clientes y estado — /clientes	GET/POST/PATCH /api/customers	sp_ListarClientes, sp_CrearCliente, sp_ActualizarCliente; triggers DML	PA10, PA21, PA27, PA28
UC10	Reportes de ventas — /reportes/ventas, detalle /ventas/:id	GET /api/reports/sales; GET /api/sales/:id	sp_ObtenerHistoricoVentas, sp_ConsultarFactura, fn_ObtenerHistoricoVentas	PA12, PA21, PA25, PA28, PA30
UC11	Administración de usuarios — /usuarios	GET/POST/PATCH /api/users; POST /api/users/:id/reset-password	sp_ListarUsuarios, sp_CrearUsuario, sp_ActualizarUsuario, sp_GenerarPasswordTemporal	PA11, PA18, PA21, PA27
UC12	Cierre, expiración y revocación — acción «Cerrar sesión»	POST /api/auth/logout; validación previa de todas las rutas protegidas	sp_CerrarSesion, sp_ValidarSesionApi, sp_ResolverSesion	PA11, PA23, PA29
UC13	Apariencia por navegador/cuenta — selectores de acceso, recuperación, restablecimiento, encabezado y /perfil	GET/PUT /api/me/preferences para cuenta; sin HTTP para preferencia anónima	sp_ObtenerPreferenciasUsuario, sp_GuardarPreferenciasUsuario	PA13–PA17, PA20, PA24
UC14	Inicio y navegación autorizada — /inicio, guardas y páginas de sistema	GET /api/dashboard; comprobación de sesión/permisos en cada endpoint	sp_ObtenerResumenInicio, sp_ValidarSesionApi, sp_ResolverSesion, fn_TienePermiso	PA18, PA19, PA23

sp_ValidarTokenRecuperacion forma parte del catálogo SQL interno, pero la API actual no lo invoca ni le concede EXECUTE a la cuenta HTTP; por eso no se presenta como eslabón del recorrido UC05.

Trazabilidad operativa fuera de UC

Operación	Entrada	SQL/artefacto	Alcance comprobable
Salud inmediata	GET /api/health; npm sql:verify	sp_VerificarEstado; scripts/Test-Database.ps1	Conectividad y permiso de ejecución del SP; no prueba salud integral ni QC.
Preparación local	scripts/Install-Database.ps1	install.sql → aprovisionamiento API → bootstrap → semilla opcional _Test	Secuencia implementada; PA32 exige ejecutarla en copia limpia y registrar evidencia.
Contrato SQL	ejecución administrativa de database/tests/01_contract.sql	catálogos sys.* y reglas puntuales	Inventario/firmas/reglas inspeccionadas por el script; no sustituye PA funcionales.
Aislamiento de contexto	database/tests/02_pool_identity_pa29.sql	sp_ResolverSesion, SESSION_CONTEXT	Caso SQL de limpieza ante sesión inválida; PA29 completo también exige alternar cuentas mediante el pool/API.
Mínimo privilegio real	RUN_SQL_INTEGRATION=true; npm test:integration	login SQL configurado en .env, sp_VerificarEstado y denegaciones directas	Comprueba un SP concedido y tres operaciones denegadas; no sustituye toda la matriz de permisos.

Operación	Entrada	SQL/artefacto	Alcance comprobable
Humo funcional real	<code>pnpm test:smoke sobre _Test</code>	API integrada, SP y datos sintéticos	Cambio inicial, permisos, tema, inventario, cotización, venta/idempotencia secuencial, comprobante y reporte; cobertura parcial de varias PA.
Rollback posterior al encabezado	<code>database/tests/04_sale-rollback-fault.sql</code>	trigger temporal transaccional y <code>sp_ProcesarVentaTransaccional</code>	Comprueba ausencia de efectos parciales e incidente separado en un punto; PA06 exige acta completa.
Interfaz en navegador	<code>pnpm test:e2e</code> ; <code>pnpm test:e2e:private</code>	Microsoft Edge, Axe, API/SQL real para el recorrido privado	Cobertura automatizada parcial de páginas, temas y viewports; teclado/zoom/estados restantes siguen manuales.
Respaldo/restauración	<code>database/operations/*.sql</code> y guía operativa	<code>BACKUP</code> , <code>VERIFYONLY</code> , <code>RESTORE</code>	Herramientas disponibles; PA31/QC07 requieren una restauración aislada medida y evidenciada.

Rutas privadas y permiso visible

Ruta	Permiso de entrada	Alcance adicional en SQL/API
<code>/inicio</code>	sesión válida	El resumen global solo se entrega con <code>REPORTES_LEER</code> ; accesos rápidos dependen de permisos.
<code>/ventas/nueva</code>	<code>VENTAS_CREAR</code>	Actor tomado de sesión; cliente/productos/stock/precios validados por SQL.
<code>/ventas</code> y <code>/ventas/:id</code>	<code>VENTAS_CREAR</code> o <code>REPORTES_LEER</code>	El primero limita a facturas propias; el segundo permite todas.
<code>/productos</code>	<code>VENTAS_CREAR</code> o <code>PRODUCTOS_GESTIONAR</code>	Solo <code>PRODUCTOS_GESTIONAR</code> muta catálogo/inventario.
<code>/clientes</code>	<code>VENTAS_CREAR</code> o <code>CLIENTES_GESTIONAR</code>	Solo <code>CLIENTES_GESTIONAR</code> muta catálogo.
<code>/reportes/ventas</code>	<code>REPORTES_LEER</code>	Rango máximo de 366 días y totales del filtro completo.
<code>/auditoria</code>	<code>AUDITORIA_LEER</code>	La cuenta API solo consulta bitácoras mediante SP.
<code>/usuarios</code>	<code>USUARIOS_GESTIONAR</code>	Protege último administrador y revoca seguridad al cambiar estado/roles.
<code>/roles</code>	<code>ROLES_GESTIONAR</code>	Protege rol administrador y revoca sesiones afectadas al cambiar permisos.
<code>/perfil</code>	sesión válida	Solo identidad, roles, permisos y preferencia de la sesión.
<code>/perfil/seguridad</code>	sesión válida, incluso cambio obligatorio	Tras cambiar contraseña se termina la sesión.

Cobertura PA transversal

Estas PA atraviesan más de un UC y deben enlazarse a evidencias por operación, no adjudicarse a una sola pantalla.

PA	Cobertura transversal
PA20	Formularios interactivos UC01–UC12; validación, conservación no sensible, navegación con cambios y cambio de tema.
PA21	Listados de facturas, productos, clientes, reportes, auditoría, usuarios y roles; filtros, paginación, orden y estados.
PA24	Todos los UC visibles: teclado, foco, etiquetas, contraste, 200 %, 320/768/1280 y ambos temas.
PA26	Todos los módulos: runtime sin Internet y fallos diferenciados de API/BD.
PA27	Límites, cuerpos estrictos, <code>rowversion</code> y concurrencia en catálogos/seguridad.
PA29	Autenticación/autorización/auditoría en conexiones reutilizadas; identidad siempre desde la sesión.
PA30	Venta y reportes bajo QC01/QC02 con dataset y equipo registrados.
PA31	Continuidad de todos los datos persistentes mediante respaldo/restauración.
PA32	Instalación, compilación, reinicio, persistencia y operación offline.

Trazabilidad de integridad de venta

```
flowchart LR
    UC03[UC03 Venta] --> UI[/ventas/nueva]
    UI --> Q[Q[POST /api/sales/quote]]
    UI --> S[S[POST /api/sales]]
    S --> TVP[TVP[dbo.TVP_DetalleFactura]]
    S --> SP[SP[sp_ProcesarVentaTransaccional]]
    SP --> F[F[(Factura)]]
    SP --> D[D[(Detalle_Factura)]]
    SP --> P[P[(Producto/stock)]]
    SP --> C[C[(MovimientoCaja)]]
    SP --> A[A[(Auditoría DML)]]
    SP --> R[R[sp_ConsultarResultadoVenta]]
    F --> PAs[PA05 PA06 PA07 PA08 PA10 PA22 PA28]
```

Regla de mantenimiento

Cuando cambie una ruta, SP o permiso, se actualizan en la misma revisión:

1. este mapa;
2. Contratos API;
3. Catálogo SQL;
4. la PA afectada sin alterar su resultado observado previo; si el contrato cambió, se programa una nueva corrida.

También se actualiza el conteo de inventario del README de documentación. Si falta un arnés necesario, se conserva la PA en **Pendiente** y se registra el hueco; no se infiere **Aprobada** ni **Bloqueada** sin una corrida y causa documentadas.

Manual de usuario

Antes de empezar

SecureFinance ERP es una aplicación local. Para utilizarla deben estar activos SQL Server y la API en el equipo autorizado. El runtime está diseñado sin CDN ni servicio externo, pero la operación sin Internet todavía debe comprobarse mediante PA26/PA32. Una conexión a Internet no sustituye una API o base detenida.

Use una cuenta individual. No comparta contraseñas, credenciales temporales, enlaces de recuperación ni capturas con datos privados. Los menús dependen de los permisos de la cuenta y una opción ausente no se habilita cambiando la URL.

Acceso y sesión

Iniciar sesión

1. Abra `/acceso`.
2. Escriba el usuario y la contraseña exactamente como fueron entregados. El usuario admite letras ASCII, números, punto, guion y guion bajo.
3. Seleccione **Acceder**.
4. Si la credencial es temporal, el sistema conduce a `/perfil/seguridad`; los demás módulos permanecen bloqueados hasta cambiarla.

Los mensajes de credencial inválida o cuenta inactiva son deliberadamente generales. Después de varios intentos puede aparecer una espera por limitación; no repita envíos rápidos.

Cerrar sesión

Abra el menú de la cuenta en el encabezado y elija **Cerrar sesión**. La sesión del servidor se revoca, la cookie se elimina y se vuelve a `/acceso`. Cierre sesión antes de dejar el equipo; cerrar solamente una pestaña no equivale a cerrar la sesión.

La sesión también termina por inactividad, vencimiento absoluto, desactivación de cuenta, cambio de contraseña o cambio de permisos. Si ocurre, se limpian los datos privados en memoria y se solicita acceso de nuevo.

Recuperación y contraseñas

Recuperar acceso

1. Desde `/acceso`, elija **Recuperar acceso**.
2. Escriba usuario o correo y seleccione **Solicitar recuperación**.
3. La respuesta siempre indica que la solicitud fue recibida. Si la cuenta existe y está habilitada, el administrador encontrará la instrucción en el canal privado configurado.
4. Abra el enlace de `/restablecer` antes de 15 minutos. Es de un solo uso.
5. Escriba y confirme la contraseña nueva.

Nunca solicite que el enlace o token se publique en una captura, chat o incidencia. Un enlace vencido o consumido debe reemplazarse con una solicitud nueva.

Cambiar contraseña

En el menú de la cuenta, abra **Seguridad**. Introduzca la contraseña actual o temporal, la nueva y su confirmación. La contraseña nueva debe tener:

- entre 12 y 128 caracteres;
- al menos una mayúscula y una minúscula;
- al menos un número;
- al menos un símbolo.

No se eliminan espacios al principio o al final. Tras el cambio, todas las sesiones y tokens de recuperación anteriores quedan revocados y se debe iniciar sesión con la contraseña nueva.

Apariencia: Claro, Oscuro y Sistema

El selector **Apariencia** está disponible en las pantallas públicas, el encabezado privado y **Mi perfil**.

Opción	Comportamiento
Claro	Fondo cálido claro y superficies blancas; no sigue cambios del sistema operativo.
Oscuro	Fondo grafito y superficies oscuras; no sigue cambios del sistema operativo.
Sistema	Sigue <code>prefers-color-scheme</code> ; si el navegador no lo ofrece, resuelve a Claro.

Cambiar la opción no recarga la página ni debe borrar formularios, filtros, diálogos o una venta en edición. Antes de acceder, la preferencia es anónima y pertenece al navegador. Después de acceder, se usa la preferencia de la cuenta almacenada en SQL. Al cerrar sesión se restaura la preferencia anónima, de modo que las cuentas no comparten tema.

Si el guardado falla, el tema se mantiene durante la sesión y aparece «**Aplicado en esta sesión; no se pudo guardar**». Seleccione **Reintentar** cuando el servicio vuelva. Los cambios rápidos se serializan y la última selección es la deseada. Otra pestaña actualiza la preferencia al recuperar foco, salvo que tenga un cambio local pendiente.

La impresión del comprobante siempre usa fondo claro, aun si la pantalla está en Oscuro; no modifica la preferencia.

Navegación y permisos

En escritorio, use la barra lateral. En pantallas estrechas, abra **Menú** en el encabezado y ciérrelo después de elegir una ruta. El enlace **Saltar al contenido** permite omitir la navegación con teclado.

Opción	Quién suele verla	Uso
Inicio	cualquier sesión válida	Tareas autorizadas y, con REPORTES_LEER , resumen disponible.
Nueva venta	VENTAS_CREAR	Cotizar y confirmar una venta.
Facturas / Mis ventas	VENTAS_CREAR o REPORTES_LEER	Consultar e imprimir comprobantes autorizados.
Productos	venta o gestión de productos	Consulta; mantenimiento/stock solo con gestión.
Clientes	venta o gestión de clientes	Consulta; mantenimiento solo con gestión.
Reportes	REPORTES_LEER	Ventas confirmadas por rango.
Auditoría	AUDITORIA_LEER	Accesos, DML y DDL.
Usuarios	USUARIOS_GESTIONAR	Cuentas, estado, roles y credencial temporal.
Roles y permisos	ROLES_GESTIONAR	Roles y permisos efectivos.
Mi perfil / Seguridad	cualquier sesión válida	Datos propios, apariencia y contraseña.

Una ruta inexistente muestra **Página no encontrada** y permite volver a Inicio. Una ruta conocida sin permiso muestra **Acceso no autorizado**. Volver, recargar o alterar la interfaz no debe exponer contenido de otra cuenta.

Inicio

/inicio muestra saludo, hora de actualización y accesos rápidos compatibles con la cuenta. Quien posee **REPORTES_LEER** puede ver el resumen autorizado; un Cajero sin ese permiso no ve métricas globales.

Distinga estos estados:

- **Preparando/Cargando:** aún no hay resultado.
- **Cero:** la consulta terminó correctamente y el valor es cero.
- **Sin datos:** no existen filas para ese alcance.
- **Error:** el servicio no pudo completar una fuente; use **Reintentar**.

Un error no representa cero. Actualizar debe volver a pedir los datos y cambiar la hora mostrada.

Registrar una venta

1. Cliente

En **/ventas/nueva**, busque por nombre o identificación y elija un cliente activo. Si no aparece, revise la búsqueda o solicite a quien posea **CLIENTES_GESTIONAR** que lo cree/active.

2. Productos

Busque código o descripción y agregue productos con existencia. Cada producto aparece una sola vez; aumente o reduzca su cantidad en la línea. Se permiten hasta 100 productos distintos y de 1 a 9999 unidades por producto. El borrador vive solo en memoria y se pierde al abandonar la página o terminar la sesión.

3. Cotización

Seleccione **Cotizar venta**. SQL Server obtiene precios y existencias actuales y devuelve subtotal, IVA y total. El precio mostrado antes de confirmar no procede de un valor editable del navegador. Si cambia cliente, producto o cantidad, actualice la cotización.

4. Confirmación

Revise cliente, líneas, subtotal, IVA y total; luego seleccione **Confirmar venta** y confirme el diálogo. Una venta correcta abre o permite abrir su comprobante. No actualice la página ni pulse repetidamente mientras está en curso.

Si aparece **Resultado desconocido**, no cree otra venta ni cambie la clave del borrador. Use **Consultar resultado**. La aplicación consulta la misma operación hasta encontrar la factura o mantenerla pendiente. Después de una sesión nueva, revise **Mis ventas** antes de repetir manualmente.

Conflictos

- **Existencia insuficiente:** ajuste cantidades y vuelva a cotizar; otra sesión pudo consumir el stock.
- **Total cambió:** revise la cotización actual; no fuerce el total anterior.
- **Resultado desconocido:** conserve la operación y resuelva con la misma clave.
- **Servicio no disponible:** no se considera confirmada; si el envío pudo alcanzar el servidor, reconcilie primero.

Facturas y comprobantes

En `/ventas`, un Cajero ve sus propias facturas. Un usuario con `REPORTES_LEER` puede seleccionar alcance **Todas** o **Propias**. Filtre por factura/cliente y fechas. Aplicar un filtro vuelve a la página 1; puede mostrar 10, 25 o 50 filas.

Abra una factura para ver cliente y cajero históricos, líneas, cantidades, precios, subtotal, IVA y total. Seleccione **Imprimir** para la vista del navegador. Consultar o imprimir nunca registra otra venta. Los cambios posteriores de cliente, producto o precio no reescriben el comprobante.

Productos e inventario

Quien vende puede consultar productos activos y stock. Con `PRODUCTOS_GESTIONAR` también puede:

Crear o editar

1. Seleccione **Nuevo producto** o el icono **Editar**.
2. Complete código (1–30), descripción (2–160), unidad del catálogo y precio sin IVA (`0.01–999999.99`).
3. Guarde. Un producto nuevo comienza con stock 0.

Desactive un producto en vez de borrarlo. Si otra persona lo actualizó, se muestra conflicto de edición; cierre/recargue, revise el dato vigente y repita conscientemente.

Ajustar inventario

1. Elija **Ajustar inventario**.
2. Introduzca un entero positivo para entrada o negativo para salida; no use cero.
3. Escriba un motivo de 10–250 caracteres.
4. Confirme.

El stock nunca puede quedar negativo. Todo ajuste conserva stock anterior/nuevo, actor, motivo, fecha y correlación.

Clientes

Quien vende puede buscar clientes activos. Con `CLIENTES_GESTIONAR`, seleccione **Nuevo cliente** o **Editar** y complete:

- identificación: 1–30;
- nombre o razón social: 2–120;
- correo opcional: hasta 254;
- teléfono opcional: hasta 30.

Desactivar conserva las facturas históricas. Un conflicto indica que el registro cambió desde que se abrió; recargue y revise antes de sobrescribir.

Reportes de ventas

Con `REPORTES_LEER`, abra `/reportes/ventas`, indique **Desde** y **Hasta** y aplique. El intervalo máximo es 366 días inclusivos. La tabla contiene ventas confirmadas y los totales corresponden a todo el filtro, no solo a la página visible.

Una tabla vacía significa consulta correcta sin filas. Un panel de error significa que no hay resultado fiable; no copie ceros como métricas. Abra el detalle desde la fila para consultar/imprimir la factura histórica.

Auditoría

Con `AUDITORIA_LEER`, abra `/auditoria` y seleccione:

- **Accesos:** intentos, resultado público/interno autorizado, actor si fue resuelto, IP y correlación.
- **Cambios DML:** tabla, operación, registro, actor de aplicación, principal SQL e imágenes anterior/nueva sanitizadas.
- **Esquema DDL:** evento, objeto, principal SQL y comando administrativo.

Use búsqueda, rango y paginación. La auditoría es de solo lectura desde la cuenta de aplicación. No debe contener contraseñas, hashes, salts, cookies, tokens o cadenas de conexión; si observa uno, limite acceso a la evidencia y abra una incidencia de seguridad.

Usuarios

Con `USUARIOS_GESTIONAR`:

1. Cree una cuenta con usuario, nombre visible, correo opcional y roles.
2. Copie la contraseña temporal solo en el momento mostrado y entréguela por un canal privado. No la incluya en evidencia.
3. El usuario debe cambiarla al primer acceso.

- 4. Para editar, cambie nombre, correo, estado o roles y guarde con la versión vigente.
- 5. **Restablecer contraseña** genera otra credencial temporal, revoca sesiones/tokens y vuelve obligatorio el cambio.

Desactivar o cambiar roles afecta la siguiente operación protegida. El sistema impide dejar la instalación sin un administrador operativo. No intente resolver ese control desde la interfaz del navegador.

Roles y permisos

Con **ROLES_GESTIONAR** , cree o edite nombre (3–60), descripción, estado y permisos. Los permisos disponibles son los siete códigos documentados en Contratos API. Guardar un cambio revoca sesiones de usuarios afectados para que la autorización no quede obsoleta.

El rol administrador protegido no puede perder **USUARIOS_GESTIONAR** ni **ROLES_GESTIONAR** , ni desactivarse. El aprovisionamiento bootstrap excluye **VENTAS_CREAR** : el nombre **Administrador** no permite vender por sí solo y esa capacidad debe asignarse explícitamente mediante otro rol.

Perfil

/perfil presenta datos propios, roles y permisos efectivos, junto con el selector de apariencia. Es informativo: un permiso que no aparece no se obtiene editando la página. Use **Cambiar contraseña** para ir a Seguridad.

Formularios, tablas y accesibilidad

- Use **Tab / Shift+Tab** para avanzar/retroceder, **Enter** o **Espacio** para activar controles y **Escape** para cerrar un diálogo cuando esté disponible.
- El foco visible indica dónde actuará el teclado. Al abrir/cerrar un diálogo debe moverse y regresar de forma controlada.
- Los errores señalan el campo y conservan datos no sensibles. Contraseñas/tokens pueden limpiarse por seguridad.
- Antes de salir con cambios operativos sin guardar, lea el aviso y elija permanecer o salir. Cambiar solo el tema no cuenta como cambio del negocio.
- En tablas anchas use el desplazamiento interno. A 200 % o en móvil, la navegación cambia a menú y los paneles se apilan.

Resolución rápida de problemas

Mensaje/síntoma	Acción segura
«Tu sesión terminó»	Vuelva a /acceso ; no reutilice formularios privados de la sesión anterior.
«No tienes permiso»	Confirme la cuenta/rol con un administrador; no altere la URL.
«La información cambió»	Recargue el registro, compare y vuelva a aplicar el cambio.
«No hay existencias suficientes»	Reduzca cantidad o solicite un ajuste autorizado; vuelva a cotizar.
«No se pudo conectar con el servicio»	Compruebe API/SQL; no interprete el fallo como operación confirmada.
«Resultado desconocido» en venta	Mantenga la misma clave y use Consultar resultado o Mis ventas .
Tema aplicado pero no guardado	Continúe si lo desea y use Reintentar cuando la API regrese.
Página no encontrada	Seleccione Ir al inicio y use la navegación disponible.

Las conductas descritas son el contrato y la guía operativa esperados, no un acta de ejecución. Autenticación, ventas, permisos, visuales, teclado, concurrencia, continuidad y operación offline solo se declaran observados después de ejecutar la PA correspondiente y adjuntar evidencia. PA01–PA32 permanecen **Pendiente**.

Respaldo y restauración

Objetivos y límites

- Objetivo de pérdida máxima (RPO): **24 horas**.
- Objetivo de recuperación (RTO): **60 minutos**.
- Copia completa diaria y copia adicional inmediatamente antes de cada migración.
- Conservar al menos siete copias válidas protegidas y una copia verificada en otro medio.
- Restaurar siempre primero con otro nombre de base. Ningún procedimiento de esta guía sobrescribe automáticamente `SecureFinanceERP`.

Estos valores son objetivos QC07, no resultados medidos. Solo una restauración cronometrada y documentada permite informar cumplimiento.

Responsabilidades

Rol operativo	Responsabilidad
Administrador SQL	Ejecutar/verificar <code>BACKUP</code> , controlar restauraciones y permisos.
Administrador del equipo	Programar la tarea, proteger carpetas/medio y vigilar capacidad.
Responsable de pruebas	Restaurar en base aislada, verificar invariantes y registrar evidencia.
Usuario de API	Ninguna: la cuenta de aplicación no recibe permisos <code>BACKUP</code> , <code>RESTORE</code> ni acceso a archivos de copia.

Ubicaciones y seguridad

Use una carpeta dedicada, por ejemplo `C:\SecureFinanceBackups`, que no esté dentro del repositorio, `apps/web/dist` ni el buzón de recuperación. La cuenta del servicio de SQL Server necesita escritura en el destino primario; los usuarios ordinarios y la cuenta de la API no.

Los nombres recomendados son únicos y UTC:

```
SecureFinanceERP_FULL_20260923T030000Z.bak
SecureFinanceERP_PREMIG_20260923T151500Z.bak
```

No incluya servidor, usuario, contraseña o datos personales en el nombre. Proteja el segundo medio con cifrado del volumen y control de acceso. Si se usa cifrado nativo de backup, custodie certificado y clave privada por separado; una copia sin su material criptográfico no es restaurable.

Copia completa manual

Antes de ejecutar:

1. confirme instancia y nombre exacto de la base;
2. confirme que la ruta pertenece a la carpeta prevista y tiene espacio suficiente;
3. cree un nombre nuevo; no reutilice ni trunque una copia válida;
4. registre inicio UTC, operador, edición/build de SQL Server y motivo (`DAILY` o `PRE_MIGRATION`).

Ejecute con una cuenta administrativa en SSMS o `sqlcmd`, sustituyendo únicamente la ruta por un nombre nuevo:

```
USE master;
GO
DECLARE @Archivo nvarchar(260) =
    N'C:\SecureFinanceBackups\SecureFinanceERP_FULL_20260923T030000Z.bak';

BACKUP DATABASE [SecureFinanceERP]
TO DISK = @Archivo
WITH COPY_ONLY, CHECKSUM, STATS = 5;
GO
```

`COPY_ONLY` evita alterar una estrategia diferencial futura. Puede añadirse `COMPRESSION` solo después de confirmar que la edición/entorno lo admite y de medir CPU/espacio. No use `INIT` sobre una ruta existente.

En PowerShell, una ejecución con autenticación integrada puede invocar un archivo operativo externo al repositorio:

```
$sfSqlInstance = '.\SQLEXPRESS'
$sfBackupScript = 'C:\SecureFinanceOps\Backup-SecureFinance.sql'
sqlcmd -S $sfSqlInstance -E -b -i $sfBackupScript
if ($LASTEXITCODE -ne 0) { throw 'El respaldo de SecureFinance falló.' }
```

No coloque credenciales en la línea de comandos ni dentro de la tarea programada. Si no se usa autenticación integrada, recurra al almacén de secretos autorizado del equipo.

Verificación inmediata

Que exista un `.bak` no demuestra que sea utilizable. Ejecute sobre el archivo recién creado:

```
RESTORE VERIFYONLY
FROM DISK = N'C:\SecureFinanceBackups\SecureFinanceERP_FULL_20260923T030000Z.bak'
WITH CHECKSUM;
GO

RESTORE HEADERONLY
FROM DISK = N'C:\SecureFinanceBackups\SecureFinanceERP_FULL_20260923T030000Z.bak';
GO
```

Registre el resultado, tamaño y un hash SHA-256 calculado después de cerrar el archivo:

```
Get-FileHash -Algorithm SHA256 -LiteralPath 'C:\SecureFinanceBackups\SecureFinanceERP_FULL_20260923T030000Z.bak'
```

`VERIFYONLY` comprueba legibilidad/estructura del conjunto, pero no reemplaza una restauración ni `DBCC CHECKDB`.

Programación diaria en Windows

SQL Server Express no incluye SQL Server Agent. Por tanto, la política no depende de Agent:

1. guarde un script operativo revisado en `C:\SecureFinanceOps` con ACL restringida;
2. cree una cuenta de servicio local con solo los derechos necesarios para iniciar la tarea y conectarse como operador de backup;
3. en **Programador de tareas**, cree una tarea diaria fuera del horario de mayor uso;
4. configure **Ejecutar tanto si el usuario inició sesión como si no**, sin almacenar una contraseña en el script;
5. acción: `powershell.exe -NoProfile -NonInteractive -ExecutionPolicy AllSigned -File C:\SecureFinanceOps\Invoke-SecureFinanceBackup.ps1`;
6. haga que el script termine con código distinto de cero ante fallo de `BACKUP`, `VERIFYONLY`, copia secundaria o hash;
7. supervise historial/último resultado y genere una alerta local; una tarea «ejecutada» sin verificar el `.bak` cuenta como fallo.

Si la edición instalada sí dispone de Agent, puede usarse un job equivalente, pero documente cuál mecanismo quedó activo. Nunca programe ambos sin coordinación porque competirían por I/O y retención.

Retención y segundo medio

- Conserve como mínimo las últimas siete copias diarias verificadas.
- Las copias previas a migración se conservan hasta validar la migración y completar la siguiente restauración periódica.
- Copie al segundo medio solo después de `VERIFYONLY`; vuelva a calcular SHA-256 en el destino y compare.
- No cuente una unidad mapeada que vive en el mismo disco físico como segundo medio.
- Antes de eliminar una copia, resuelva su ruta absoluta, confirme que está dentro de la carpeta exclusiva y que quedan siete copias válidas más la secundaria. Prefiera cuarentena/papelera antes de borrado definitivo.
- Registre creación, verificación, traslado y retiro en un manifiesto sin secretos.

Restauración aislada

1. Preparación

1. declare incidente o ejercicio, inicio UTC y operador;
2. seleccione la última copia válida de acuerdo con manifiesto/hash;
3. reserve un nombre nuevo, por ejemplo `SecureFinanceERP_Restore_20260923`;
4. confirme que `DB_ID(N'SecureFinanceERP_Restore_20260923') IS NULL`;
5. no cambie `DB_NAME` de la API y no permita que usuarios normales entren a la base restaurada;
6. identifique nombres lógicos, sin adivinarlos:

```
RESTORE FILELISTONLY
FROM DISK = N'C:\SecureFinanceBackups\SecureFinanceERP_FULL_20260923T030000Z.bak';
GO
```

2. Restaurar con otro nombre

Sustituya `SecureFinanceERP` / `SecureFinanceERP_log` por los nombres lógicos devueltos y use rutas de datos autorizadas para la instancia:

```

USE master;
GO
IF DB_ID(N'SecureFinanceERP_Restore_20260923') IS NOT NULL
    THROW 51006, N'La base de destino ya existe; elija otro nombre.', 1;
GO

RESTORE DATABASE [SecureFinanceERP_Restore_20260923]
FROM DISK = N'C:\SecureFinanceBackups\SecureFinanceERP_FULL_20260923T030000Z.bak'
WITH
    MOVE N'SecureFinanceERP' TO N'C:\SecureFinanceRestore\SecureFinanceERP_Restore_20260923.mdf',
    MOVE N'SecureFinanceERP_log' TO N'C:\SecureFinanceRestore\SecureFinanceERP_Restore_20260923_log.ldf',
    CHECKSUM,
    RECOVERY,
    STATS = 5;
GO

```

No añade **WITH REPLACE**; no restaure encima de producción durante una prueba. Si hay más archivos en **FILELISTONLY**, proporcione un **MOVE** único para cada uno.

3. Invalidar credenciales recuperadas

Una copia puede contener sesiones y tokens que eran válidos cuando se creó. Antes de conectar una API de verificación, ejecute dentro de la base restaurada:

```

USE [SecureFinanceERP_Restore_20260923];
GO
BEGIN TRANSACTION;
    UPDATE dbo.Sesion
        SET RevocadaUtc = COALESCE(RevocadaUtc, SYSUTCDATETIME());

    UPDATE dbo.TokenRecuperacion
        SET RevocadoUtc = COALESCE(RevocadoUtc, SYSUTCDATETIME())
        WHERE UsadoUtc IS NULL;
COMMIT TRANSACTION;
GO

```

Esto forma parte del ejercicio de recuperación y debe constar en el acta. No crea ni publica una contraseña de administrador.

4. Integridad técnica

```

DBCC CHECKDB (N'SecureFinanceERP_Restore_20260923') WITH NO_INFOMSGS, ALL_ERRORMSG;
GO

```

Confirme también nivel de compatibilidad, objetos esperados y que la base está **ONLINE**. Un **CHECKDB** sin mensajes no demuestra por sí solo la coherencia funcional.

5. Verificación funcional mínima

En la base restaurada y con datos sintéticos conocidos, registre conteos y muestras sin copiar secretos:

```

USE [SecureFinanceERP_Restore_20260923];
GO
SELECT COUNT_BIG(*) AS Usuarios FROM dbo.Usuario;
SELECT COUNT_BIG(*) AS Facturas FROM dbo.Factura;
SELECT COUNT_BIG(*) AS Detalles FROM dbo.Detalle_Factura;

SELECT f.FacturaId, f.Numero, f.Subtotal, f.IVA, f.Total,
    COUNT_BIG(d.DetalleFacturaId) AS Lineas,
    COUNT_BIG(mc.MovimientoCajaId) AS MovimientosCaja
FROM dbo.Factura AS f
LEFT JOIN dbo.Detalle_Factura AS d ON d.FacturaId = f.FacturaId
LEFT JOIN dbo.MovimientoCaja AS mc ON mc.FacturaId = f.FacturaId
WHERE f.FacturaId = @FacturaPruebaId
GROUP BY f.FacturaId, f.Numero, f.Subtotal, f.IVA, f.Total;

SELECT ProductoId, Codigo, Stock
FROM dbo.Producto
WHERE ProductoId = @ProductoPruebaId;
GO

```

Además verifique que:

- las cuentas de prueba esperadas existen y sus roles concuerdan;
- la factura elegida conserva encabezado y líneas históricas;
- tiene exactamente un movimiento de caja por el total esperado;
- el stock del producto concuerda con la venta/ajustes registrados;
- no existe stock negativo;
- todos los objetos/SP requeridos están presentes;
- sesiones y tokens no usados quedaron revocados.

No inicie sesión con contraseñas tomadas de consultas ni extraiga PasswordHash , PasswordSalt , SesionHash o TokenHash como evidencia.

Medición de QC07 / PA31

Registre al menos:

Campo	Valor de la corrida
ID de ejercicio	—
Estado	Pendiente
Inicio de incidente/restauración UTC	—
Hora del último backup válido UTC	—
Fin de recuperación/verificación UTC	—
Pérdida calculada	—
Duración calculada	—
Archivo y SHA-256	—
Base de destino	—
VERIFYONLY / CHECKDB	—
Factura/producto sintético verificado	—
Sesiones/tokens invalidados	—
Evidencia	—
Responsable/incidencia	—

La pérdida se calcula entre el último dato confirmado que debía recuperarse y el punto real del backup; la duración va desde la declaración del ejercicio hasta que las verificaciones acordadas terminan. No reste tiempos manualmente para mejorar el resultado.

Promoción tras un incidente real

La decisión de sustituir una base dañada es administrativa y queda fuera de una restauración de prueba. Requiere autorización, ventana de mantenimiento, detener escrituras, preservar la base/archivos originales, confirmar cadenas de conexión, plan de reversión y comunicación a usuarios. Esta guía no autoriza DROP DATABASE , WITH REPLACE ni cambios automáticos de la API hacia una copia restaurada.

Lista de comprobación

- [] Copia completa diaria con nombre único.
- [] Copia previa a migración.
- [] CHECKSUM , VERIFYONLY , tamaño y SHA-256 registrados.
- [] Al menos siete copias protegidas.
- [] Copia verificada en otro medio.
- [] Tarea supervisada y fallo visible.
- [] Restauración periódica con otro nombre.
- [] DBCC CHECKDB y verificación funcional.
- [] Sesiones/tokens restaurados revocados.
- [] RPO/RTO medidos, no inferidos.
- [] Evidencia sin secretos enlazada a PA31/QC07.

El estado inicial de PA31 y QC07 es **Pendiente**.

Matriz de pruebas PA01–PA32

Regla de estado

Todas las pruebas se inicializan en **Pendiente**. Solo una ejecución observable puede cambiar el estado:

- **Pendiente:** todavía no ejecutada.
- **En ejecución:** existe una corrida abierta.
- **Aprobada:** resultado observado coincide con todos los resultados esperados y la evidencia está enlazada.
- **Fallida:** uno o más resultados no coinciden; debe existir incidencia.
- **Bloqueada:** no puede ejecutarse por una causa externa concreta, por ejemplo SQL Server o navegador ausente. Un mock no desbloquea pruebas de ACID, TVP, concurrencia o restauración.

La lectura del código, una compilación correcta o una prueba parcial no autorizan a marcar una PA como Aprobada.

En esta revisión no existe `docs/evidence/manifest.csv` ; por ello ninguna PA tiene evidencia oficial enlazada y PA01–PA32 continúan **Pendiente**.

Definiciones

ID	UC	Escenario	Resultado esperado	Estado inicial
PA01	UC01, UC04	Probar acceso con credenciales válidas, inválidas y una cuenta inactiva.	Solo la cuenta habilitada obtiene sesión. Los rechazos usan respuesta pública genérica y la bitácora registra el motivo interno sin secretos.	Pendiente
PA02	UC02	Cambiar la contraseña de una cuenta, comparar el salt y probar la contraseña anterior y la nueva.	Cambia el salt; la contraseña anterior falla; la nueva funciona; las sesiones y tokens anteriores quedan revocados.	Pendiente
PA03	UC05	Probar token de recuperación vencido, consumido y dos restablecimientos simultáneos con el mismo token.	Un token vencido o usado falla. En la carrera concurrente solo un restablecimiento consume el token y tiene éxito.	Pendiente
PA04	UC04, UC06, UC07	Como Cajero, manipular interfaz y llamar directamente endpoints de auditoría y roles.	La UI no ofrece las acciones y la API/SQL rechazan auditoría y roles; alterar el cliente nunca concede permiso.	Pendiente
PA05	UC03	Procesar una venta correcta y verificar factura, detalle, stock, caja e IVA con subtotal <code>100.00</code> .	Todos los efectos concuerdan en una sola venta; IVA <code>12.00</code> , total <code>112.00</code> ; no hay efectos omitidos o duplicados.	Pendiente
PA06	UC03	Inyectar una falla después de crear el encabezado de factura.	No quedan factura parcial, detalle, movimiento de caja ni descuento de stock. El incidente técnico se registra después del rollback y por separado.	Pendiente
PA07	UC03	Con stock igual a uno, enviar dos ventas simultáneas por la última unidad.	Solo una venta se confirma; la otra recibe conflicto de stock; el stock final es cero, nunca negativo.	Pendiente
PA08	UC03	Enviar dos veces la misma venta y simular pérdida de la primera respuesta usando la misma clave y contenido.	La misma clave y contenido devuelve la misma factura; existe una factura y un movimiento de caja.	Pendiente
PA09	UC03, UC08	Actualizar varios productos en una sentencia y provocar también un rollback.	El trigger audita cada fila cambiada. La transacción revertida no conserva auditoría DML de cambios que no persistieron.	Pendiente
PA10	UC03	Enviar cantidades negativas, identificadores ajenos, precios alterados e intentos de inyección.	Los valores inválidos se rechazan; el texto de inyección se trata como dato; precios, impuestos, stock e identidad se obtienen de fuentes autorizadas.	Pendiente
PA11	UC07, UC11, UC12	Cerrar sesión, dejarla vencer, revocarla, desactivar usuario y retirar permisos durante una sesión.	Cookies cerradas/vencidas fallan; desactivar, revocar o cambiar permisos surte efecto en la siguiente operación protegida.	Pendiente
PA12	UC04, UC10	Comparar reportes con ventas confirmadas e intentar editar auditoría con la cuenta SQL de API.	El reporte contiene únicamente ventas confirmadas; la cuenta API no puede editar bitácoras; ninguna bitácora contiene secretos.	Pendiente
PA13	UC13	Recorrer toda la interfaz en Claro y Oscuro y cambiar tema con formularios/diálogos abiertos.	Ambos temas cubren toda la UI; el cambio no recarga, cierra diálogos ni borra formularios, filtros o venta en edición.	Pendiente
PA14	UC13	Seleccionar sistema y cambiar <code>prefers-color-scheme</code> ; repetir con Claro y Oscuro explícitos.	Solo Sistema sigue al sistema operativo. Claro y Oscuro permanecen fijos. Si no se detecta preferencia, Sistema resuelve a Claro.	Pendiente
PA15	UC13	Guardar Oscuro en cuenta A, Claro en B, alternar cuentas y cerrar sesión.	Cada cuenta recupera su preferencia sin mezclarla; al salir se restaura la preferencia anónima de acceso.	Pendiente
PA16	UC13	Forzar fallo al guardar apariencia, continuar usando la sesión y luego reintentar.	El tema se aplica en memoria; aparece «Aplicado en esta sesión; no se pudo guardar»; el reintento persiste y no afecta otras operaciones.	Pendiente
PA17	UC13	Hacer cambios rápidos de tema, probar navegador sin almacenamiento y sincronizar otra pestaña al recuperar foco.	Se conserva la última selección; sin almacenamiento local la sesión opera; otra pestaña actualiza al foco salvo que tenga un cambio local pendiente.	Pendiente
PA18	UC06, UC14	Iniciar como Cajero, probar métricas, URL/API prohibida, volver, recargar y alternar cuenta.	Cajero no ve métricas globales; URL y API prohibidas fallan; volver/recargar no revela datos de otra cuenta.	Pendiente
PA19	UC14	Probar Inicio durante carga, con cero datos, con una fuente fallida y al actualizar.	Carga, cero válido y fallo son distintos; hora/datos se actualizan; una tarjeta fallida no bloquea las demás.	Pendiente
PA20	UC01–UC12 interactivos	Provocar validación y tratar de salir con cambios sin guardar; cambiar tema durante la edición.	El error identifica el campo y conserva valores no sensibles; el aviso permite permanecer; cambiar tema no avisa ni borra datos.	Pendiente
PA21	Listados	Probar búsqueda, filtros, páginas 10/25/50, orden estable, totales y estados vacío/fallo.	Filtrar vuelve a página uno; el orden es estable; el total cubre todo el filtro; «sin registros», «sin coincidencias» y fallo de servicio no se confunden.	Pendiente

ID	UC	Escenario	Resultado esperado	Estado inicial
PA22	UC03	Provocar doble envío y pérdida/fallo de respuesta durante una venta.	El borrador queda pendiente con la misma clave; se resuelve en una sola factura; no se habilita nueva clave mientras el resultado sea incierto.	Pendiente
PA23	UC06, UC12, UC14	Vencer sesión, abrir ruta inexistente/prohibida y probar una cuenta sin roles.	Vencimiento limpia datos sensibles; ruta inexistente ofrece volver a Inicio; ruta prohibida rechaza; sin roles conserva solo funciones personales.	Pendiente
PA24	Todos	Operar acceso y venta solo con teclado, revisar foco/etiquetas/contraste, zoom 200 % y anchos 320/768/1280 en ambos temas.	Las acciones esenciales son operables, el foco es visible y controlado, hay nombres accesibles, el contraste cumple y el contenido general no desborda.	Pendiente
PA25	UC03, UC10	Consultar e imprimir comprobantes como Cajero y como usuario con REPORTES_LEER , desde tema Oscuro.	Cajero solo accede a facturas propias; REPORTES_LEER accede a todas; la impresión es clara sobre fondo blanco y no crea otra venta.	Pendiente
PA26	Todos	Desconectar Internet después de instalar; detener API o base durante una operación.	El sistema local funciona sin Internet. Una caída de API/BD se informa como fallo y nunca confirma una operación ni presenta cero válido.	Pendiente
PA27	Transversal	Probar mínimos/máximos, un valor por encima, campos inesperados y versiones obsoletas en ediciones concurrentes.	Los límites se aplican sin truncado; campos extra se rechazan; no hay duplicados ni sobrescritura silenciosa; una versión obsoleta devuelve conflicto.	Pendiente
PA28	UC03, UC08, UC10	Vender, cambiar cliente/producto/precio, reimprimir y probar subtotal 0.05 .	El comprobante histórico permanece idéntico; IVA 0.01 , total 0.06 ; los cambios de catálogo no reescriben la venta.	Pendiente
PA29	UC01, UC04, UC06; transversal	Alternar cuentas sobre conexiones reutilizadas, enviar otro UsuarioId e inspeccionar auditoría y permisos.	Identidad, permisos y auditoría proceden de la sesión; el identificador del navegador y un contexto residual del pool no cambian el actor.	Pendiente
PA30	UC03, UC10; QC01, QC02	Ejecutar carga con el dataset prescrito, cinco sesiones y registrar equipo, errores, máximos y percentiles.	Las mediciones válidas producen percentiles reproducibles sin errores, pérdida de integridad ni afirmaciones sin acta.	Pendiente
PA31	QC07	Restaurar la última copia válida en otra base y verificar cuentas, factura, detalle, stock y caja.	La base restaurada es íntegra; se registran pérdida y duración frente a RPO 24 h/RTO 60 min; sesiones y tokens recuperados se invalidan.	Pendiente
PA32	QC06	En una copia limpia, preparar SQL, instalar con lockfile, compilar, iniciar y reiniciar sin Internet.	El arranque es reproducible; el reinicio conserva facturas y configuración; el runtime funciona offline con API y SQL activos.	Pendiente

Preparación pendiente para ejecutar la matriz

Estos huecos del paquete no cambian automáticamente el estado a **Bloqueada**; identifican trabajo previo para poder abrir una corrida válida.

Alcance	Herramienta existente	Hueco que debe resolverse o cubrirse manualmente
PA01–PA05, PA08, PA10–PA12, PA18–PA23, PA25, PA27–PA29	Aplicación, API, scripts SQL y semilla pequeña _Test	Preparar datos/roles exclusivos, coordinador de casos, capturas y consultas posteriores; registrar revisión y entorno.
PA03, PA07, PA08, PA22, PA29	Casos SQL parciales y endpoints funcionales	Hace falta coordinación simultánea real. Llamadas secuenciales o mocks no acreditan una carrera ni reutilización del pool.
PA06 y rollback por etapa de QC03	database/tests/04_sale-rollback-fault.sql crea un trigger temporal dentro de la transacción en una base _Test y verifica el punto posterior al encabezado	Añadir otros puntos de fallo si el protocolo exige cobertura por etapa y conservar salida/entorno en el manifiesto; la cuenta API no puede activar este mecanismo.
PA09	Triggers por conjuntos	Preparar DML administrativo multiregistro y una transacción revertida; verificar una fila de auditoría por registro y ausencia tras rollback.
PA13–PA17 y PA24	Vitest/RTL, Playwright público en 18 combinaciones y recorrido privado real de 14 vistas con Axe/capturas	Ejecutar todavía teclado, zoom 200 %, diálogos/formularios durante cambio de tema, preferencia Sistema y estados de fallo; la suite actual es parcial.
PA30 / QC01–QC02	Plan de medición	No hay generador del dataset prescrito ni arnés de cinco sesiones/percentiles. La semilla demo no cumple el volumen.
PA31 / QC07	Scripts de backup, verificación y restauración	Ejecutar restauración aislada, cronometrar RPO/RTO y conservar manifiesto/hash/validaciones; VERIFYONLY solo no basta.
PA32 / QC06	Instalador, lockfile, build/start	Ejecutar desde copia limpia y repetir sin Internet después de obtener dependencias; una compilación en el workspace actual no acredita reproducibilidad.

Registro de ejecución

Cada fila debe completarse durante una ejecución real. **Evidencia** utiliza rutas relativas conforme a Guía de evidencia. No se registran contraseñas, tokens, cookies, hashes, salts ni cadenas de conexión.

ID	Estado	Fecha/hora UTC	Entorno y versiones	Datos/precondiciones	Resultado observado	Evidencia	Ejecutor	Incidencia/bloqueo
PA01	Pendiente	—	—	—	—	—	—	—
PA02	Pendiente	—	—	—	—	—	—	—
PA03	Pendiente	—	—	—	—	—	—	—
PA04	Pendiente	—	—	—	—	—	—	—
PA05	Pendiente	—	—	—	—	—	—	—
PA06	Pendiente	—	—	—	—	—	—	—

ID	Estado	Fecha/hora UTC	Entorno y versiones	Datos/precondiciones	Resultado observado	Evidencia	Ejecutor	Incidencia/bloqueo
PA07	Pendiente	—	—	—	—	—	—	—
PA08	Pendiente	—	—	—	—	—	—	—
PA09	Pendiente	—	—	—	—	—	—	—
PA10	Pendiente	—	—	—	—	—	—	—
PA11	Pendiente	—	—	—	—	—	—	—
PA12	Pendiente	—	—	—	—	—	—	—
PA13	Pendiente	—	—	—	—	—	—	—
PA14	Pendiente	—	—	—	—	—	—	—
PA15	Pendiente	—	—	—	—	—	—	—
PA16	Pendiente	—	—	—	—	—	—	—
PA17	Pendiente	—	—	—	—	—	—	—
PA18	Pendiente	—	—	—	—	—	—	—
PA19	Pendiente	—	—	—	—	—	—	—
PA20	Pendiente	—	—	—	—	—	—	—
PA21	Pendiente	—	—	—	—	—	—	—
PA22	Pendiente	—	—	—	—	—	—	—
PA23	Pendiente	—	—	—	—	—	—	—
PA24	Pendiente	—	—	—	—	—	—	—
PA25	Pendiente	—	—	—	—	—	—	—
PA26	Pendiente	—	—	—	—	—	—	—
PA27	Pendiente	—	—	—	—	—	—	—
PA28	Pendiente	—	—	—	—	—	—	—
PA29	Pendiente	—	—	—	—	—	—	—
PA30	Pendiente	—	—	—	—	—	—	—
PA31	Pendiente	—	—	—	—	—	—	—
PA32	Pendiente	—	—	—	—	—	—	—

Datos y mecanismos especiales

- PA03, PA07, PA08, PA22 y PA29 requieren coordinación concurrente real, no llamadas secuenciales presentadas como carrera.
- PA05–PA09 y PA22 usan SQL Server real y verificaciones posteriores desde un canal administrativo de solo prueba.
- PA06 y PA09 usan inyección de fallos aislada, imposible de activar desde la cuenta o servicio normal.
- PA24 registra tema, viewport, zoom, navegador, entrada utilizada y violación concreta, no solo una captura visual.
- PA30 sigue las condiciones de Plan QC.
- PA31 restaura siempre en otra base; nunca reemplaza automáticamente la base existente.

Plan de calidad QC01–QC08

Este documento define cómo medir los objetivos. No contiene resultados y un objetivo escrito no implica que exista el arnés para medirlo. Hasta completar una corrida válida con manifiesto, todos los QC permanecen **Pendiente**.

Entorno obligatorio

- Base exclusiva de pruebas con Microsoft SQL Server real.
- API y navegador en el mismo equipo, por loopback.
- Cinco sesiones representan cinco clientes de prueba concurrentes en el mismo equipo.
- Equipo de referencia: al menos 16 GB de RAM y SSD, sin cargas intensivas durante la medición. No es un mínimo funcional del producto.
- Registrar CPU, RAM, almacenamiento, sistema operativo, navegador, Node, npm, SQL Server/edición/build y configuración relevante de base/pool.
- Dependencias fijadas por `pnpm-lock.yaml`; reloj estable y plan de energía documentado.

Dataset prescrito

Conjunto	Cantidad
Clientes	1,000
Productos	10,000
Facturas	50,000
Líneas de factura	250,000

Los datos son sintéticos e identificados como prueba. La semilla/generador debe ser reproducible y ejecutarse solo por el canal administrativo. No se vuelve a sembrar al iniciar la aplicación.

El repositorio actual no incluye el generador de este volumen ni el arnés concurrente de cinco sesiones. `database/seed-demo.sql` solo prepara un cliente y dos productos, por lo que no puede usarse para informar QC01, QC02 o PA30. El generador y el ejecutor de carga deben incorporarse o identificarse en el acta antes de abrir la corrida.

Protocolo común de medición

1. Preparar la base exclusiva, comprobar conteos e integridad y registrar el hash/versión del dataset.
2. Reiniciar de forma documentada solo los componentes que el protocolo de la corrida indique; no limpiar cachés selectivamente entre muestras.
3. Ejecutar **20 operaciones de calentamiento por escenario**. No se incorporan al percentil.
4. Ejecutar **al menos 100 mediciones válidas por escenario**.
5. Para concurrencia, iniciar las cinco sesiones desde una barrera común y registrar la distribución real de inicios.
6. Medir extremo a extremo desde la petición hasta que los datos estén visibles y utilizables, no solo el tiempo SQL.
7. Separar rechazos funcionales esperados de errores técnicos. Registrar ambos, además del máximo.
8. Ordenar las duraciones válidas y calcular p95 con rango más cercano: posición `ceil(0.95 × N)`. Con 100 muestras corresponde a la muestra 95 ordenada.
9. Conservar datos crudos, resumen, errores y correlaciones. No redondear antes de calcular.

Un objetivo solo cumple si al menos 95 % de las mediciones válidas está bajo el umbral y no hay errores técnicos o pérdida de integridad que invalide la corrida.

Objetivos

QC01 — Consultas y reporte

Objetivo: consultas habituales p95 ≤ 2 s; reporte de hasta 366 días p95 ≤ 5 s.

Escenarios representativos mínimos:

- productos: primera página, búsqueda selectiva, filtro de estado y orden alternativo;
- clientes: búsqueda y cambio de página;
- ventas propias: lista y comprobante;
- auditoría: categoría y rango cuando el actor tenga permiso;
- reporte de ventas: rango de 366 días con totales del filtro completo.

La medición termina cuando filas, totales y estado accesible se muestran. Un error, respuesta incompleta o total calculado solo sobre la página invalida la muestra.

QC02 — Venta concurrente

Objetivo: venta de hasta 100 líneas p95 ≤ 3 s con cinco sesiones concurrentes.

- Precrear cinco cajeros, clientes y productos con stock suficiente.
- Usar claves UUID diferentes entre ventas y conservar cada clave para reconciliación.
- Incluir el escenario máximo de 100 productos distintos; registrar también tamaños menores como diagnóstico.
- Verificar después de cada lote facturas, líneas, movimientos de caja, movimientos de stock, idempotencia y stock no negativo.
- Si hay una respuesta incierta, resolverla con la misma clave antes de contabilizar la muestra.

QC03 — Integridad

Objetivo: cero ventas parciales, duplicadas o con stock negativo.

Ejecutar PA05–PA09 y PA22, incluyendo última unidad y fallos después de encabezado, detalle, stock, caja y auditoría. Consultas administrativas posteriores deben demostrar:

- toda factura confirmada tiene detalle y exactamente un movimiento de caja;
- no hay clave de idempotencia duplicada por usuario;
- no hay líneas duplicadas por producto dentro de factura;
- ningún stock es negativo;
- un fallo revierte todos sus efectos de negocio;
- la auditoría transaccional describe únicamente cambios persistentes.

QC04 — Autorización

Objetivo: cero accesos indebidos en la matriz de permisos.

Ejecutar PA04, PA18, PA23 y PA25 por UI y por llamada HTTP directa. Probar Administrador sin `VENTAS_CREAR`, Cajero, Auditor, cuenta sin roles, cuenta inactiva y permiso revocado durante la sesión. Alternar identidades sobre el pool para confirmar aislamiento.

QC05 — Usabilidad y accesibilidad

Objetivo: todas las acciones esenciales operables con teclado y ambos temas.

Ejecutar PA13–PA17 y PA24. Revisar acceso, inicio, nueva venta, comprobante y pantallas administrativas en Claro/Oscuro, 320/768/1280 px y texto al 200 %. Registrar contraste, foco, orden de tabulación, etiquetas, nombre accesible, diálogo, reducción de movimiento y desbordamiento.

La suite Playwright pública cubre acceso/recuperación/restablecimiento en dos temas y 320/768/1280. La suite privada recorre vistas esenciales de Administrador y Cajero contra API/SQL reales, usa Axe, controla desbordamiento y produce capturas en una base `_Test`. Aun así, teclado completo, zoom 200 %, edición con diálogos abiertos, cambio de sistema operativo y la matriz total de estados requieren el protocolo manual; esta automatización parcial no aprueba PA24.

QC06 — Instalación y operación offline

Objetivo: arranque reproducible y operación sin Internet tras instalar dependencias.

En una copia limpia: instalar con lockfile congelado, preparar SQL, compilar, iniciar, ejecutar un recorrido esencial, desconectar Internet y repetir. Reiniciar API/SQL/equipo según el acta y comprobar persistencia. Corresponde a PA26 y PA32.

QC07 — Continuidad

Objetivo: pérdida máxima de 24 h (RPO) y recuperación en 60 min (RTO).

Restaurar la última copia válida en una base diferente. Medir desde la declaración del incidente hasta la validación técnica y funcional. Verificar cuentas, factura, detalle, stock, caja, integridad y la invalidación de sesiones/tokens recuperados. Comparar la última transacción recuperada con la última conocida.

QC08 — Trazabilidad

Objetivo: cada evento crítico identifica actor, fecha, resultado y operación.

Cruzar solicitud, respuesta, correlación y bitácora para acceso, cambio/restablecimiento de contraseña, permisos, usuario, rol, producto, inventario, cliente, venta y DDL. Confirmar que no aparecen secretos y que cada fallo interno conserva una referencia diagnóstica autorizada.

Acta de corrida

Campo	Valor
Identificador de corrida	Pendiente
Fecha/hora UTC	Pendiente
Responsable	Pendiente
Commit/paquete entregado	Pendiente
CPU / RAM / almacenamiento	Pendiente
SO / plan de energía	Pendiente
Navegador y versión	Pendiente
Node / npm	Pendiente
SQL Server edición/build/compatibilidad	Pendiente
Pool y timeouts	Pendiente
Dataset/semilla/conteos	Pendiente
Calentamiento	20 por escenario, aún no ejecutado

Campo	Valor
Mediciones válidas requeridas	≥ 100 por escenario, aún no ejecutadas
Errores/rechazos	Pendiente
Ruta de datos crudos	Pendiente

Registro de resultados

QC	Estado	N válidas	N errores	p95	Máximo	Objetivo	Evidencia/observaciones
QC01 consultas	Pendiente	—	—	—	—	≤2 s	—
QC01 reporte 366 días	Pendiente	—	—	—	—	≤5 s	—
QC02 venta 100 líneas/5 sesiones	Pendiente	—	—	—	—	≤3 s	—
QC03 integridad	Pendiente	—	—	N/A	N/A	0 anomalías	—
QC04 autorización	Pendiente	—	—	N/A	N/A	0 accesos	—
QC05 usabilidad	Pendiente	—	—	N/A	N/A	100 % esenciales	—
QC06 reproducibilidad/offline	Pendiente	—	—	N/A	N/A	Sin dependencia Internet	—
QC07 continuidad	Pendiente	—	—	—	—	RPO≤24 h; RTO≤60 min	—
QC08 trazabilidad	Pendiente	—	—	N/A	N/A	100 % eventos críticos	—

Verificación técnica ejecutada

Alcance y advertencia

Este registro resume comprobaciones parciales ejecutadas el **24 de septiembre de 2026** sobre el workspace local. No es un manifiesto formal de aceptación, no certifica seguridad ni producción y **no cambia PA01–PA32 ni QC01–QC08 de Pendiente**. El workspace no contiene metadatos Git, por lo que la corrida queda ligada a estos archivos locales y no a un commit identificable.

Entorno observado

Componente	Valor
Sistema operativo	Windows 11 Home 10.0.26200 , build 26200
PowerShell	5.1.26100.9444
Node.js	v24.18.0
pnpm	10.34.4
SQL Server	17.0.1000.7 RTM, Express Edition 64-bit
Instancia administrativa	.\\SQLEXPRESS
Base exclusiva	SecureFinanceERP_Verification_20260923_Test
Navegador automatizado	Microsoft Edge 153.0.4234.48
Origen integrado	http://127.0.0.1:3000

No se incluyen contraseñas, cookies, hashes, tokens ni cadenas de conexión.

Resultados observados

Comprobación	Resultado	Alcance real
pnpm install --frozen-lockfile	Aprobó; lockfile vigente	Reproducibilidad de dependencias en este workspace, con caché/entorno actuales.
pnpm audit --prod	Sin vulnerabilidades conocidas informadas	Consulta puntual al registro; no es auditoría de código ni garantía futura.
pnpm lint	Aprobó API y web	Reglas estáticas configuradas.
pnpm test	16 API + 24 web = 40 aprobadas ; 3 SQL condicionales omitidas en esta orden	Unitarias/aisladas y regresiones de configuración, conexión, seguridad, componentes y formatos.
pnpm build	Aprobó	Bundle Vite de producción generado.
pnpm sql:verify	available , GTQ , America/Guatemala	Conectividad y ejecución de sp_VerificarEstado con el login mínimo de la API.
RUN_SQL_INTEGRATION=true; pnpm test:integration	3 aprobadas	SP concedido; lectura/escritura directa y SP interno denegados al login API.
database/tests/01_contract.sql	ok	Objetos, migraciones, triggers, tipos, permisos TVP y casos decimales puntuales.
database/tests/02_pool_identity_pa29.sql	ok	Limpieza de cinco claves de contexto ante sesión inválida; no cubre alternancia concurrente real.
database/tests/03_save-transaction.sql	ok	Demostración aislada de savepoint y cierre de transacción.
database/tests/04_sale-rollback-fault.sql	ok	Fallo posterior al encabezado; ausencia de efectos parciales, trigger y fixtures; incidente separado comprobado y limpiado.
pnpm test:smoke	Aprobó, 21 intercambios HTTP	Cambio inicial, revocación, permisos, inventario, tema, cotización 100.00/12.00/112.00 , venta, caja, reporte e idempotencia secuencial.
pnpm test:e2e	19 aprobadas	Tres páginas públicas, Claro/Oscuro, 320/768/1280, Axe, CSP y ausencia de errores del navegador.
pnpm test:e2e:private	1 recorrido aprobado; 14 vistas capturadas	Administrador/escritorio/claro y Cajero/móvil/oscurο contra API/SQL reales; Axe, desbordamiento y errores de consola.
Inspección visual puntual	Sin defecto abierto en las capturas revisadas	Inicio, roles, nueva venta y comprobante; la cuenta se enmascara deliberadamente en las imágenes.

La evidencia sanitizada de humo y las capturas se guardan localmente bajo docs/evidence/runtime/ , directorio excluido del control de versiones. Para una aceptación formal deben copiarse a un paquete controlado, incluir hashes/manifiesto, revisión identificable, salida íntegra y ejecutor.

Defectos encontrados y corregidos durante la corrida

- mssql intentaba mutar una configuración congelada; ahora recibe una copia mutable.
- El timeout especial de venta usaba una propiedad ignorada; ahora se pasa como requestTimeout soportado por el driver.

- Los booleanos predeterminados de Zod podían conservar cadenas truthy; ahora siempre se transforman y hay regresión automatizada.
- Los marcadores de secretos de `.env.example` se rechazan al arrancar.
- El editor de roles evaluaba una cuenta nula cuando el modal estaba cerrado.
- Se corrigieron contraste de botones deshabilitados, nombre accesible del menú móvil y fondo del detalle del comprobante oscuro.
- El botón de menú móvil dejó de mostrarse en escritorio.
- La prueba de rollback ya no deja lógica de test en el SP ni datos sintéticos persistentes.

Cobertura aún pendiente

- Carreras reales de stock, recuperación y misma clave mediante clientes simultáneos.
- Alternancia de identidades/cancelación sobre una única conexión física del pool.
- Dataset QC y carga de cinco sesiones con percentiles.
- Teclado completo, zoom 200 %, todos los diálogos/estados y matriz de navegadores.
- Desconexión de Internet y reinstalación/reinicio desde una copia limpia.
- Respaldo y restauración cronometrados con RPO/RTO y `DBCC CHECKDB` sobre la copia.
- Revisión de seguridad independiente, TLS local y migración del hash académico a un verificador con factor de trabajo.

Por estas limitaciones, la matriz oficial permanece sin resultados aprobados.

Guía de evidencia

Principios

La evidencia demuestra una ejecución, no una intención. Debe ser reproducible, estar vinculada a una PA/QC y conservar contexto suficiente para que otra persona verifique el resultado.

- No fabricar capturas, salidas ni fechas.
- No usar una captura de código como prueba de comportamiento.
- No incluir contraseñas, cookies, tokens, hashes, salts, cadenas de conexión, claves privadas, datos personales reales ni rutas privadas innecesarias.
- Mantener el identificador de correlación cuando ayude a unir UI, API y bitácora.
- Una evidencia fallida se conserva y se enlaza con la incidencia; no se reemplaza silenciosamente.
- Conservar el comando o pasos exactos, código de salida y revisión del código. Una captura aislada sin esas referencias no acredita una corrida reproducible.
- Acreditar cada resultado esperado de la PA. Un caso feliz no aprueba escenarios negativos, concurrencia, límites o persistencia incluidos en la misma fila.

Estado actual y clases de comprobación

No existe actualmente `docs/evidence/manifest.csv` ni un paquete de evidencia de runtime registrado. Por tanto, PA01–PA32 y QC01–QC08 permanecen **Pendiente**.

Clase	Ejemplos	Qué permite afirmar
Inspección estática	leer rutas, SP, permisos, esquema y documentación	Que existe una implementación diseñada; nunca que se ejecutó correctamente.
Verificación aislada	lint, Vitest con mocks, build, análisis sintáctico SQL	Solo la propiedad concreta comprobada por esa herramienta y revisión. No acredita ACID, permisos SQL reales, UI completa ni PA/QC.
Smoke test	<code>GET /api/health</code> , <code>npm sql:verify</code>	Conectividad inmediata y acceso a <code>sp_VerificarEstado</code> ; no salud integral.
Ejecución PA/QC	sistema real, datos/precondiciones prescritos, observaciones y artefactos	Puede cambiar el estado únicamente cuando cubre todos los resultados esperados y queda enlazada en el registro oficial.

Una salida de consola generada durante desarrollo no se convierte retroactivamente en evidencia oficial si no conserva entorno, revisión, datos, comando, hora y archivo íntegro. Puede repetirse bajo el protocolo y registrarse entonces.

Estructura recomendada

```
docs/evidence/
  manifest.csv
  PA05/
    AAAAMDDThhmssZ-venta-correcta.png
    AAAAMDDThhmssZ-verificacion-sql.txt
  QC01/
    run-001-environment.md
    run-001-raw.csv
    run-001-summary.json
```

No se crea contenido dentro de `docs/evidence/` hasta disponer de una ejecución real. Los nombres usan UTC y no contienen nombres de personas.

Manifiesto mínimo

Campo	Descripción
<code>evidence_id</code>	Identificador único estable.
<code>test_id</code>	PA01–PA32 o QC01–QC08.
<code>captured_at_utc</code>	Instante ISO 8601.
<code>environment_id</code>	Referencia al acta de entorno.
<code>revision</code>	Commit, hash de paquete o identificador inmutable del código ejecutado.
<code>actor_role</code>	Rol sintético usado, no nombre real.
<code>action</code>	Qué se ejecutó.
<code>command_or_steps</code>	Comando exacto o referencia a pasos numerados.
<code>exit_code</code>	Código de salida, cuando aplique; no se omite un fallo.
<code>expected</code>	Resultado esperado relevante.
<code>observed</code>	Resultado realmente observado.

Campo	Descripción
file	Ruta relativa.
sha256	Hash del archivo después de redactar.
redactions	Qué se ocultó y por qué.
correlation_id	Solo si no constituye un secreto y es útil.
executor	Responsable de la corrida.

Capturas de interfaz

Para acceso, inicio, venta, comprobante y módulos administrativos registrar:

- tema y preferencia (Claro , Oscuro o Sistema);
- viewport exacto 320, 768 o 1280 px y escala/zoom;
- navegador/versión;
- estado probado: carga, vacío, sin coincidencias, éxito, validación, conflicto o servicio caído;
- elemento enfocado cuando la prueba sea de teclado;
- consola sin errores inesperados, en una evidencia separada si es necesario.

Las capturas de comprobante deben ocultar navegación y controles de impresión, usar fondo blanco y no mostrar datos personales reales.

Evidencia API

Guardar método/ruta, estado HTTP, código público, forma de la respuesta y correlación. Redactar por completo:

- encabezados Cookie , Set-Cookie y X-CSRF-Token ;
- cuerpos con contraseña o token de recuperación;
- datos de conexión;
- trazas internas.

Ejemplo **ilustrativo, no evidencia registrada**:

```
POST /api/sales
HTTP 201
X-Correlation-Id: 7bd0...2f1c
Body: { "data": { "invoiceId": "42", "total": "112.00" } }
Cookie/CSRF: [REDACTADO]
```

Evidencia SQL

Ejecutar verificaciones con una cuenta administrativa de pruebas y guardar consulta, conteos y filas mínimas necesarias. Incluir nombre de base de prueba y build de SQL Server. No exportar columnas secretas. Para concurrencia conservar marcas de tiempo y correlaciones de ambas sesiones.

La evidencia de rollback comprueba ausencia de todos los efectos y presencia del incidente separado; una excepción de la API por sí sola no demuestra rollback.

Los archivos bajo database/tests/ no son evidencia por existir. La captura debe contener su salida completa, el código de retorno de sqlcmd , las variables no secretas utilizadas y la revisión exacta. 02_pool_identity_pa29.sql cubre un caso de limpieza de contexto, no toda PA29; 03_save-transaction.sql es didáctico; 04_sale-rollback-fault.sql cubre un único punto posterior al encabezado y tampoco aprueba PA06 sin el resto del protocolo y el acta.

Rendimiento

Conservar:

- acta de equipo/configuración;
- versión/semilla y conteos del dataset;
- 20 calentamientos identificados y excluidos;
- al menos 100 mediciones válidas por escenario;
- datos crudos sin redondear;
- script/comando exacto;
- errores, rechazos funcionales, máximo y cálculo p95;
- verificaciones de integridad posteriores.

Integridad de archivos

Después de redactar, calcular SHA-256 con PowerShell:

```
Get-FileHash -Algorithm SHA256 -LiteralPath '<ruta-de-evidencia>'
```

Registrar el hash en el manifiesto. Si el archivo cambia, crear una nueva revisión y actualizar el manifiesto; no conservar un hash que ya no corresponde.

Cambio de estado

Antes de modificar una fila de Matriz PA01–PA32, compruebe:

1. que la revisión, entorno, datos y precondiciones coinciden con la corrida;
2. que todos los resultados esperados de la PA fueron observados, incluidos casos negativos y concurrencia real cuando se exigen;
3. que cada archivo existe, fue redactado y su SHA-256 coincide con el manifiesto;
4. que el resultado observado no se dedujo de código, mocks o una PA distinta;
5. que **Aprobada**, **Fallida** o **Bloqueada** incluye ejecutor y, cuando corresponda, incidencia o causa externa concreta.

Si falta cualquiera de estos elementos, el estado continúa **Pendiente**. Esta regla también impide declarar cumplimiento QC o aptitud productiva a partir de la documentación.

Guion de demostración — 12 minutos

Preparación previa

- Usar una base de demostración identificada, nunca datos reales.
- Tener API y SQL Server activos, frontend compilado y conectividad de loopback verificada.
- Preparar credenciales privadas temporales para Administrador, Cajero y Auditor; no mostrarlas en pantalla ni incluirlas en el repositorio.
- Tener productos con stock, un cliente, una clave de venta aún no usada y un comprobante histórico.
- Cerrar herramientas que puedan mostrar secretos. Confirmar que la demo no se presenta como evidencia de PA aprobadas.

Recorrido cronometrado

Tiempo	Acción	Mensaje clave
00:00–00:40	Presentar arquitectura local y estado de la entrega.	React y Express operan bajo un origen; Express llama SP en SQL Server. Las pruebas/métricas solo se afirman con evidencia.
00:40–01:30	Abrir <code>/acceso</code> , alternar Claro/Oscuro/Sistema e iniciar como Cajero.	Preferencia anónima separada; cookie opaca HttpOnly; el Cajero no recibe funciones administrativas.
01:30–03:15	En <code>/ventas/nueva</code> , buscar cliente/productos, cambiar cantidades y cotizar.	SQL decide precio, stock, subtotal e IVA; el navegador no envía precios autoritativos. Mostrar subtotal, IVA y total como cadenas de dos decimales.
03:15–04:20	Confirmar una venta y abrir <code>/ventas/:id</code> .	Factura, detalle, stock, caja y auditoría se confirman en una transacción. La clave UUID evita duplicados.
04:20–05:00	Abrir impresión/vista previa.	El comprobante es histórico, de solo lectura, fondo blanco; imprimir no crea otra venta.
05:00–05:40	Mostrar <code>/ventas</code> y explicar "Resultado desconocido".	Ante pérdida de respuesta se conserva la misma clave y se consulta el resultado; no se repite manualmente con otra clave.
05:40–06:35	Entrar como Administrador; abrir productos y realizar un ajuste con motivo.	Producto inicia con stock cero; el ajuste es transaccional, exige motivo y <code>rowversion</code> ; el historial no se reescribe.
06:35–07:15	Mostrar clientes y estados activos/inactivos.	Se desactiva en lugar de borrar para conservar comprobantes históricos. Paginación y filtros ocurren en servidor.
07:15–08:00	Abrir reporte de ventas y filtrar fechas.	<code>REPORTES_LEER</code> ve todas las facturas y totales del filtro completo; un fallo no se presenta como cero.
08:00–08:50	Entrar como Auditor y recorrer Accesos, DML y DDL.	Mostrar actor de aplicación, principal SQL, IP, fecha, operación y resultado; revisar la muestra sin asumir ni exponer secretos.
08:50–09:45	Mostrar usuarios, roles y permisos; explicar permisos efectivos del Administrador.	El bootstrap excluye <code>VENTAS_CREAR</code> ; vender requiere un rol explícito. El nombre del rol no sustituye permisos y la API vuelve a validarlos en cada operación.
09:45–10:35	Mostrar perfil, cambio de contraseña y recuperación local.	Política 12–128 sin recorte; SHA2_512+salt es perfil académico; token de 15 minutos, digest y un solo uso.
10:35–11:15	Cerrar sesión y comprobar restauración del tema anónimo; mencionar expiración/revocación.	Cerrar limpia datos sensibles. Cambiar roles/desactivar usuario afecta la siguiente operación protegida.
11:15–12:00	Cerrar con matriz PA/QC, respaldo y limitaciones reales.	PA inicia Pendiente; QC exige dataset/medición. Express no tiene SQL Agent: respaldos con Task Scheduler. No afirmar "producción".

Variante didáctica de `SAVE TRANSACTION`

Ejecutar únicamente en la base de pruebas y fuera del flujo de venta:

1. abrir transacción;
2. crear un savepoint;
3. efectuar una modificación didáctica no comercial;
4. provocar una condición controlada;
5. consultar `XACT_STATE()`;
6. hacer rollback al savepoint solo cuando el estado lo permita;
7. revertir finalmente toda la transacción didáctica.

Explicar que una venta no usa el savepoint para conservar encabezado, detalle o caja parciales: ante cualquier fallo se revierte completa.

